

Département : STIC

Référence :

Licence Appliquée en Sciences et technologies de l'Information et de la Communication

Option SR

Projet de fin d'Études

Titre

Mise en place d'une solution XDR open source

Réalisé par : Rabeb JERBI

Classe : STIC L3 SR C

Encadré par :

**Entreprise d'Accueil : Agence Technique des
Télécommunications**

Résumé

Notre projet a pour objectif de concevoir une architecture de Centre d'Opérations de Sécurité (SOC) capable de répondre de manière exhaustive aux besoins de sécurité, en intégrant une solution de Détection et Réponse Étendues (XDR). Cette intégration permet de mettre en place des réponses actives pour contrer efficacement les attaques. En combinant la surveillance continue et approfondie du SOC avec les capacités d'analyse avancées du XDR, on assure une détection proactive des cybermenaces et une réponse rapide et coordonnée. Cette approche garantit la protection des actifs numériques de l'entreprise et assure la continuité de ses opérations en minimisant les interruptions et les dommages potentiels.

Mots clés : Sécurité informatique, SOC, XDR, Réponses actives.

Abstract

Our project aims to design a Security Operations Center (SOC) architecture that comprehensively addresses security needs by integrating an Extended Detection and Response (XDR) solution. This integration enables the implementation of active responses to effectively counter attacks. By combining the continuous and in-depth monitoring capabilities of the SOC with the advanced analytical abilities of the XDR, we ensure proactive detection of cyber threats and a swift, coordinated response. This approach guarantees the protection of the company's digital assets and ensures operational continuity by minimizing disruptions and potential damages.

Keywords : Cybersecurity, SOC, XDR, Active responses.

Table des matières

Introduction Générale	1
1 Cadre général du projet	3
1.1 Introduction.....	3
1.2 Présentation de l'organisme d'accueil	3
1.2.1 Présentation générale de l'ATT	3
1.2.2 Organigramme de l'ATT	4
1.2.3 Principales missions de l'ATT.....	5
1.3 Contexte Général du Projet.....	5
1.3.1 Problématique.....	5
1.3.2 Étude de l'existant	6
1.3.3 Critique de l'existant	7
1.3.4 Solution proposée	8
1.4 Conclusion	14
2 Étude comparative	15
2.1 Introduction.....	15
2.2 Étude Comparative des Composants	15
2.2.1 XDR (Extended Detection and Response)	15
2.2.2 SIEM (Security Information and Event Management).....	17
2.2.3 NIDS (Network-based Intrusion Detection System).....	19
2.2.4 SOAR (Security Orchestration, Automation, and Response).....	20
2.2.5 Threat Intelligence Platform.....	22
2.2.6 Pare-feu (Firewall).....	23
2.3 Load Balancer.....	24
2.4 Conclusion	26
3 Implémentation	27
3.1 Introduction.....	27
3.2 Architecture	27
3.2.1 Analyse de l'Architecture.....	28
3.2.2 Configuration d'un réseau virtuel sur Google Cloud	28
3.2.3 Installation et Configuration des Composants.....	30
3.3 Conclusion	42

4 Test	43
4.1 Introduction.....	43
4.2 Blocage d'un Acteur Malveillant	43
4.2.1 Description de l'attaque	43
4.2.2 Attaque Simulée	44
4.3 Injection SQL	47
4.3.1 Description de l'attaque	47
4.3.2 Attaque Simulée	47
4.4 Attaque Shellshock	50
4.4.1 Description de l'attaque	50
4.5 Scan Nmap	52
4.5.1 Description de l'attaque	52
4.5.2 Émulation des Attaques.....	52
4.6 Conclusion	54
Conclusion Générale	55
A Annexes	58

Table des figures

1.1	Logo de l'Agence Technique des Télécommunications.....	3
1.2	Organigramme de la société	4
2.1	XDR Wazuh.....	16
2.2	Microsoft Defender XDR.....	16
2.3	Palo Alto Networks Cortex XDR.....	17
2.4	SIEM Wazuh.....	17
2.5	Splunk.....	18
2.6	QRadar	18
2.7	Logo Suricata	19
2.8	Logo Zeek	19
2.9	Logo Snort.....	20
2.10	Logo Cortex XSOAR	20
2.11	Logo Splunk Phantom.....	21
2.12	Logo Cortex.....	21
2.13	Logo MISP.....	22
2.14	Logo Recorded Future.....	22
2.15	Logo ThreatConnect	23
2.16	Logo Pfsense	23
2.17	Logo Cisco ASA.....	24
2.18	Logo Fortinet FortiGate	24
2.19	Logo HAProxy	25
2.20	Logo Nginx.....	25
2.21	Logo F5 BIG-IP	25
3.1	Architecture	27
3.2	Réseau	29
3.3	Vérification du Gestionnaire Wazuh.....	30
3.4	Configuration du Fichier de Configuration sur le Gestionnaire.....	31
3.5	Configuration du Fichier de Configuration sur le Worker.....	31
3.6	Test du Cluster	32
3.7	Activation de Nginx	32
3.8	Configuration de Nginx.....	32
3.9	Installation de MISP	33

3.10	Création d'une Organisation	34
3.11	Création d'un Utilisateur	34
3.12	Activation des Flux de Renseignements sur les Menaces	35
3.13	Création d'une Organisation	36
3.14	Création d'un Utilisateur Activer les flux de renseignements sur les menaces	36
3.15	Résultat de l'Intégration	37
3.16	Création d'une Organisation	38
3.17	Création d'un Utilisateur	38
3.18	Intégration de VirusTotal	39
3.19	Intégration de TheHive avec MISP et Cortex	39
3.20	Statut de l'Agent Wazuh	40
3.21	Activation et Démarrage de l'Agent Wazuh	40
3.22	Configuration de l'Agent Wazuh	41
3.23	Status de wazuh manager	41
3.24	Démarrage de l'Agent Wazuh sur pfSense	41
4.1	Blocage d'un Acteur Malveillant	43
4.2	Simulation de l'attaque	44
4.3	Alerte Wazuh	44
4.4	Détails de l'alerte Wazuh	45
4.5	Alerte dans The Hive	45
4.6	Alerte VirusTotal	46
4.7	Configuration de la réponse active dans Wazuh	47
4.8	injection SQL	47
4.9	Simulation d'attaque	48
4.10	Tentative d'injection SQL	48
4.11	Alerte dans The Hive	49
4.12	réponse active	49
4.13	Alertes Wazuh	50
4.14	Simulation d'attaque	50
4.15	Simulation d'attaque	51
4.16	Alertes Wazuh	51
4.17	Réponse active	51
4.18	Alerte Wazuh	52
4.19	Simulation d'attaque	53
4.20	script	53
4.21	Alertes Wazuh	53
4.22	Réponse active	54

Liste des tableaux

- 3.1 Les interfaces de PfSense29
- 3.2 Table d'adressage29
- 3.3 Les machines30

Liste des abréviations

CISO	Chief Information Security Officer
EDR	Détection et Réponse aux Incidents sur les Points de Terminaison
GCP	Google Cloud Platform
IDS	Systèmes de Détection d’Intrusion
IPS	Systèmes de Prévention d’Intrusion
MISP	Malware Information Sharing Platform
NIDS	Network-based Intrusion Detection System
PCI-DSS	Payment Card Industry Data Security Standard
RGPD	Règlement Général sur la Protection des Données
SIEM	Gestion des Informations et des Événements de Sécurité
SOC	Centre d’Opérations de Sécurité
SOAR	Orchestration, Automatisation, et Réponse à la Sécurité
TTP	Tactiques, Techniques et Procédures
VPN	Virtual Private Network
XDR	Extended Detection and Response

Introduction Générale

Dans un monde marqué par une évolution technologique rapide, la sécurité informatique devient cruciale pour les organisations de toutes tailles. La complexité croissante des infrastructures numériques interconnectées expose les entreprises à un éventail de vulnérabilités et de risques cybernétiques. Ce contexte exige une vigilance constante et une adaptation agile des stratégies de sécurité pour envisager les cyberattaques de plus en plus sophistiquées et diversifiées, allant du phishing aux attaques par déni de service et aux infiltrations ciblant des données sensibles.

Les Centres d'Opérations de Sécurité (SOC) et les solutions de Détection et Réponse Étendues (XDR) sont au cœur de cette stratégie défensive. Les SOC assurent une surveillance continue et approfondie, détectant rapidement les activités suspectes grâce à l'analyse comportementale et à des technologies avancées telles que l'intelligence artificielle et l'apprentissage automatique. Ces capacités permettent non seulement de détecter les menaces en temps réel, mais aussi de prévoir les attaques potentielles en analysant les tendances et les comportements anormaux. La capacité à intervenir rapidement est essentielle pour prévenir les incidents avant qu'ils ne compromettent la sécurité.

Parallèlement, les solutions XDR complètent les capacités des SOC en intégrant des données issues de multiples sources—réseaux, endpoints, serveurs, et environnements cloud pour offrir une vue holistique et faciliter une réponse coordonnée aux incidents. Cette approche intégrée permet de corréliser les données provenant de différentes couches de l'infrastructure informatique, ce qui renforce la capacité de détection et réduit les temps de réponse. En fournissant une visibilité complète sur l'ensemble de l'écosystème de l'organisation, les solutions XDR permettent de détecter les menaces cachées et d'automatiser les réponses pour une efficacité accrue.

Pour L'Agence Technique des Télécommunications(ATT), l'adoption de ces solutions est devenue indispensable face à l'augmentation des cybermenaces et à la complexité croissante de ses infrastructures numériques. ATT a besoin d'une surveillance continue et d'une détection proactive des menaces pour protéger ses actifs numériques sensibles. L'intégration de SOC et de solutions XDR permet à ATT de renforcer sa résilience face aux attaques et d'assurer la continuité de ses opérations en minimisant les interruptions et les dommages potentiels. En outre, ces technologies aident ATT à se conformer aux réglementations de sécurité et à réduire

les risques financiers liés aux incidents de sécurité.

Ce rapport est structuré en quatre chapitres. Le premier chapitre, intitulé "Cadre général du projet", présente l'entreprise et le projet, en expliquant les motivations et les objectifs de l'initiative de sécurité. Le deuxième chapitre, "Choix de la solution", propose une étude comparative des composants utilisés dans notre solution, justifiant le choix des technologies et des outils déployés. Le troisième chapitre, "Implémentation", décrit les étapes de configuration de notre architecture de sécurité, fournissant des détails sur l'installation et l'intégration des différentes composantes. Enfin, le quatrième chapitre, "Test", évalue notre architecture en simulant diverses attaques pour en tester l'efficacité et la robustesse, avec les résultats des tests et les ajustements effectués. En conclusion, dans un contexte où les cybermenaces ne cessent de croître en sophistication et en fréquence, les Centres d'Opérations de Sécurité et les solutions de Détection et Réponse Étendues constituent des éléments fondamentaux pour développer une défense robuste et agile, augmentant la résilience des entreprises face à un large spectre de cybermenaces.

Chapitre 1

Cadre général du projet

1.1 Introduction

Ce premier chapitre établit le contexte du projet, essentiel pour comprendre l'environnement global dans lequel cette initiative est déployée. Nous commencerons par une présentation de l'organisme d'accueil, incluant son organigramme et ses missions. Ensuite, nous aborderons le contexte général du projet en définissant la problématique et en présentant une étude de l'existant, avec une critique des solutions actuelles et de leurs limitations. Enfin, nous proposerons une solution adaptée en définissant le concept de Centre d'Opérations de Sécurité (SOC) et en présentant la solution détaillée.

1.2 Présentation de l'organisme d'accueil

1.2.1 Présentation générale de l'ATT

L'Agence Technique des Télécommunications est un établissement public à caractère administratif, créé pour apporter un appui technique dans le domaine judiciaire des crimes liés aux systèmes d'information et de communication. Placée sous la tutelle du Ministère des Technologies de la Communication, elle jouit de la personnalité morale et de l'autonomie financière. Cette structure est destinée à agir en tant qu'acteur central dans la lutte contre les crimes informatiques, tout en facilitant la coopération technique entre différents opérateurs et acteurs du domaine des télécommunications.



FIGURE 1.1 – Logo de l'Agence Technique des Télécommunications

1.2.2 Organigramme de l'ATT

L'organigramme de la société, présenté par la figure 1.2 ci-dessous, illustre la structure hiérarchique et les principales divisions fonctionnelles, offrant une vue d'ensemble de l'organisation interne et des responsabilités de chaque département.

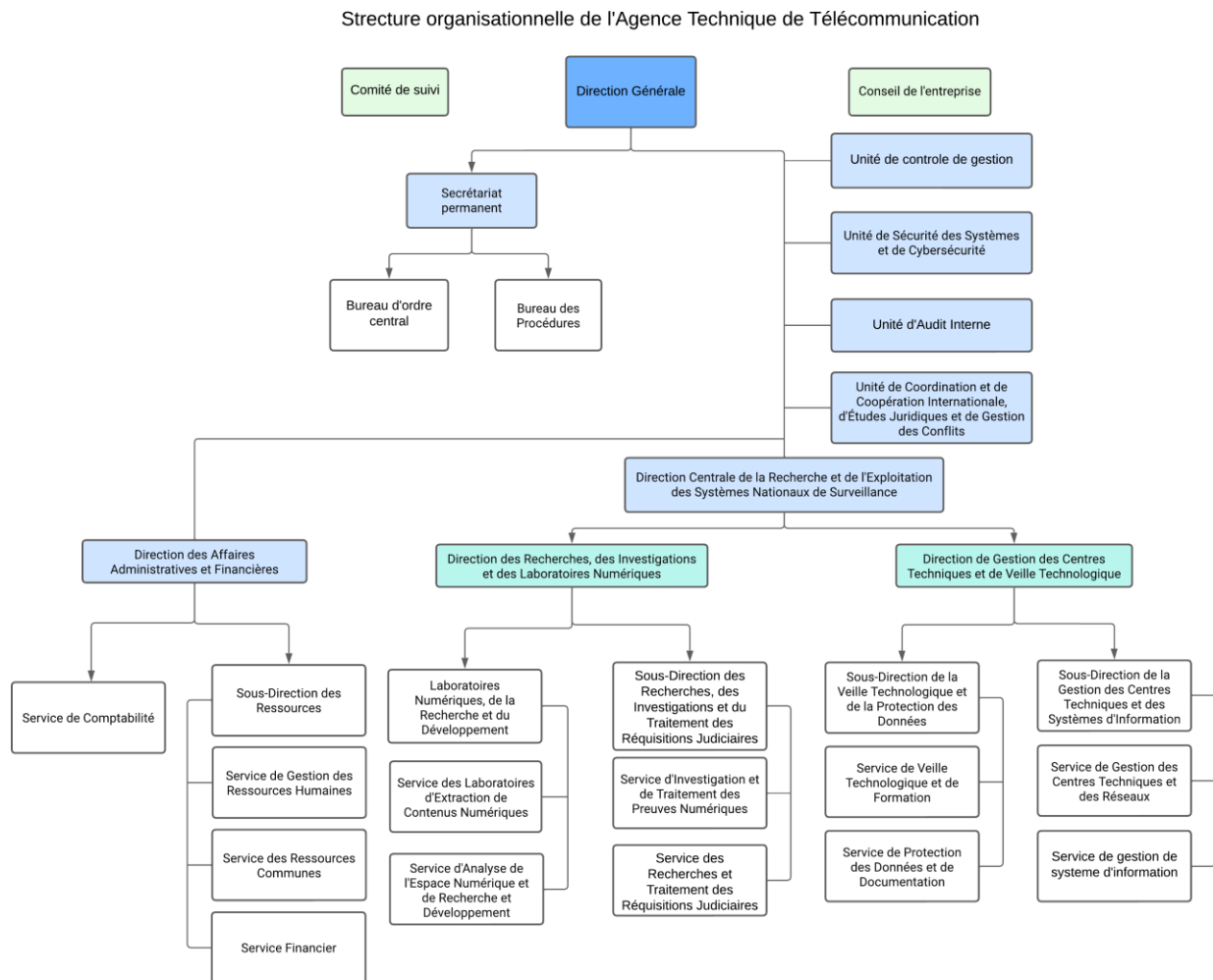


FIGURE 1.2 – Organigramme de la société

L'agence est structurée autour de plusieurs entités clés, dont :

- **Le Directeur Général** : Nommé par décret, il est chargé de la gestion administrative, financière, et technique de l'agence, de la présidence du comité de suivi, de la représentation de l'agence auprès des tiers et de l'exécution de diverses autres missions.
- **Le Comité de Suivi** : Composé de membres nommés par décret pour veiller à la bonne exploitation des systèmes nationaux de contrôle du trafic des télécommunications, dans le respect de la protection des données personnelles et des libertés publiques.
- **Le Secrétariat Permanent** : Assure le secrétariat des travaux du comité de suivi et la rédaction des procès-verbaux de ses réunions.
- **Les Services Spécifiques** : Comprennent la direction des études et enquêtes, la direction

d'exploitation des systèmes, chargées de l'analyse, de la coordination, et de l'exploitation technique des ordres d'investigation.

- **La Direction des Affaires Administratives et Financières** : Gère les ressources humaines, les achats nécessaires au fonctionnement de l'agence, et prépare son budget.

1.2.3 Principales missions de l'ATT

L'agence technique des télécommunications assure l'appui technique aux investigations judiciaires dans les crimes des systèmes d'information et de la communication, elle est à cet effet chargée des missions suivantes :

- La réception et le traitement des ordres d'investigation et de constatation des crimes des systèmes d'information et de la communication issus du pouvoir judiciaire conformément à la législation en vigueur.
- La coordination avec les différents opérateurs de réseaux publics de télécommunications et opérateurs de réseaux d'accès et tous les fournisseurs de services de télécommunications concernés, dans tout ce qui se relève de ses missions conformément à la législation en vigueur.
- L'exploitation des systèmes nationaux de contrôle du trafic des télécommunications dans le cadre du respect des traités internationales relatifs aux droits de l'Homme et des cadres législatifs relatifs à la protection des données personnelles.

1.3 Contexte Général du Projet

1.3.1 Problématique

De nos jours, les réseaux informatiques sont de plus en plus vulnérables aux attaques et aux intrusions en raison des outils avancés utilisés par les pirates modernes. Bien qu'il soit considéré comme impossible de concevoir un réseau totalement sécurisé, détecter et bloquer les tentatives d'intrusion reste un élément clé pour la sécurité d'un réseau informatique. En effet, les cyberattaques sont de plus en plus élaborées et peuvent causer de graves dommages aux entreprises et aux utilisateurs. Les intrusions peuvent prendre différentes formes telles que l'usurpation d'identité, l'installation de logiciels malveillants ou encore la divulgation de données confidentielles. Ce qui peut engendrer la perte de données importantes, la violation de la vie privée des utilisateurs, des pertes financières ou une atteinte à la réputation d'entreprise.

De plus, la complexité croissante des réseaux informatiques et la diversité des types d'attaques augmentent le nombre de faux positifs et de faux négatifs dans les résultats de détection d'intrusion. Par conséquent, le développement de nouveaux outils et techniques de détection d'intrusion est une problématique majeure pour les experts en sécurité informatique afin de

protéger les systèmes contre les attaques malveillantes et réduire les risques de pertes de données ou de dommages financiers.

Notre projet consiste à mettre en place un système de Détection et Réponse Étendues (XDR) utilisant des outils gratuits et open source. Ce système s'inscrit dans le contexte plus large de la sécurité informatique et vise à fournir une solution efficace pour protéger les systèmes contre les attaques malveillantes.

1.3.2 Étude de l'existant

Dans la plupart des entreprises, les solutions de sécurité informatique se basent sur des outils simples et éprouvés pour assurer une protection de base des réseaux et des systèmes. Ces solutions comprennent des dispositifs et logiciels largement adoptés qui fournissent des défenses initiales contre les menaces courantes. Malgré leur simplicité, ces outils jouent un rôle crucial dans la sécurisation des infrastructures informatiques en contrôlant l'accès, en surveillant le trafic et en protégeant contre les logiciels malveillants. Voici un aperçu des solutions les plus couramment utilisées :

- **Firewalls** : Les firewalls, ou pare-feux, sont des dispositifs de sécurité réseau qui jouent un rôle essentiel dans la protection des infrastructures informatiques. Ils surveillent et contrôlent le trafic réseau entrant et sortant en fonction de règles de sécurité prédéfinies. En agissant comme une barrière entre un réseau interne sécurisé et des réseaux externes non sécurisés, tels que "Internet", les firewalls permettent de prévenir les accès non autorisés et de bloquer les menaces connues. Leur configuration est relativement simple et ils constituent la première ligne de défense contre les attaques externes, offrant un contrôle granulaire du trafic réseau.
- **Antivirus/Antimalware** : Les logiciels antivirus et antimalware sont des outils indispensables pour protéger les systèmes informatiques contre les logiciels malveillants. Ils sont conçus pour détecter, prévenir et éliminer les virus, les vers, les chevaux de Troie, les ransomwares et d'autres types de malwares. Faciles à installer et à utiliser, ces logiciels offrent une protection de base contre les menaces connues en analysant les fichiers et les programmes pour détecter les comportements suspects. Ils sont essentiels pour maintenir l'intégrité et la sécurité des données dans un environnement informatique.
- **Systèmes de Détection d'Intrusion (IDS)** : Les systèmes de détection d'intrusion (IDS) sont des dispositifs ou logiciels utilisés pour surveiller le réseau ou les systèmes afin de détecter des activités malveillantes ou des violations de politiques. Ils analysent le trafic réseau ou les journaux système pour identifier des comportements anormaux ou des signatures d'attaques connues. En fournissant des alertes en temps réel, les IDS permettent aux administrateurs de sécurité de réagir rapidement aux incidents potentiels. Ils peuvent être intégrés à d'autres systèmes de sécurité pour une protection renforcée et une meilleure visibilité sur les menaces.

- **Systèmes de Prévention d’Intrusion (IPS) :** Les systèmes de prévention d’intrusion (IPS) vont au-delà des IDS en non seulement détectant, mais aussi en empêchant les menaces. Ils surveillent en temps réel le trafic réseau et prennent des mesures immédiates pour bloquer les activités malveillantes, telles que les tentatives d’exploitation de vulnérabilités. Les IPS offrent une réactivité accrue aux menaces et protègent efficacement contre une large gamme d’attaques. Leur capacité à intervenir automatiquement réduit le risque de dommages potentiels, offrant ainsi une couche supplémentaire de sécurité proactive.
- **VPN (Virtual Private Network) :** Les réseaux privés virtuels créent des tunnels sécurisés pour le transfert de données sur des réseaux non sécurisés, comme le réseau Internet. En chiffrant les données transmises entre les utilisateurs et les ressources internes de l’entreprise, les VPN protègent les informations sensibles contre les interceptions et les écoutes. Ils permettent aux employés de se connecter de manière sécurisée aux réseaux de l’entreprise partout dans le monde, facilitant ainsi le travail à distance et l’accès sécurisé aux ressources critiques.

1.3.3 Critique de l’existant

Bien que les solutions mentionnées précédemment soient couramment utilisées et constituent une base essentielle pour la sécurité des réseaux, elles présentent certaines limitations :

- **Firewalls :** Bien qu’ils sont indispensables, les pare-feu présentent des limitations significatives. Ils sont souvent incapables de détecter les attaques sophistiquées qui utilisent des techniques d’évasion avancées pour contourner les règles de sécurité prédéfinies. De plus, pour maintenir leur efficacité, les firewalls nécessitent des mises à jour régulières des règles de filtrage, ce qui peut être chronophage et complexe à gérer. Ainsi, ils exigent des maintenances continues pour adapter leurs règles aux nouvelles menaces et aux différents changements dans le réseau.
- **Antivirus/Antimalware :** Les logiciels antivirus et antimalware offrent une protection de base, mais leur efficacité est limitée contre les menaces nouvelles et avancées, telles que les attaques zero-day qui exploitent des vulnérabilités inconnues. En outre, ces logiciels peuvent consommer des ressources système importantes, ralentissant ainsi les performances des machines sur lesquelles ils sont installés. Ils dépendent également fortement de mises à jour régulières des bases de signatures pour détecter les nouvelles menaces, ce qui peut créer des vulnérabilités temporaires si les mises à jour ne sont pas effectuées rapidement.
- **Systèmes de Détection d’Intrusion (IDS) :** Les IDS sont efficaces pour détecter des activités suspectes, mais ils génèrent souvent un grand nombre de faux positifs, ce qui peut submerger les administrateurs de sécurité et rendre difficile la distinction entre les menaces réelles et les alertes bénignes. La surveillance continue et l’analyse manuelle des alertes sont nécessaires pour vérifier les incidents potentiels, ce qui demande du temps et des ressources humaines qualifiées. Cette dépendance à l’analyse manuelle peut également

retarder la réponse aux incidents critiques.

- **Systèmes de Prévention d’Intrusion (IPS) :** Les IPS partagent certaines des limitations des IDS, mais avec l’ajout de la prévention active. Ils peuvent bloquer par erreur du trafic légitime, entraînant des interruptions de service non souhaitées et des perturbations pour les utilisateurs. La complexité de la configuration des IPS peut également être un défi, nécessitant une expertise technique approfondie pour définir des règles précises qui minimisent les faux positifs tout en maximisant la protection. De plus, comme pour les IDS, une surveillance et une maintenance continues sont nécessaires.
- **VPN (Virtual Private Network) :** Les VPN offrent une sécurité accrue pour les communications, mais ils peuvent également réduire la vitesse de connexion en raison du chiffrement et du routage supplémentaire des données. La gestion des clés et des certificats est essentielle pour garantir la sécurité des connexions VPN, et une mauvaise gestion peut conduire à des vulnérabilités. Les VPN ne protègent pas contre toutes les formes d’attaques, notamment celles qui ciblent les utilisateurs finaux via des méthodes de phishing ou de logiciels malveillants.

1.3.4 Solution proposée

Pour mieux comprendre l’importance et l’efficacité de la solution proposée par ce projet, il est essentiel de d’abord saisir les fondamentaux des Centres d’Opérations de Sécurité (SOC). Notre solution s’intègre dans ce cadre conceptuel, agissant comme une composante cruciale d’un SOC. Pour cette raison, avant de détailler notre solution, il est nécessaire de comprendre le rôle et le fonctionnement d’un SOC, afin de percevoir comment notre solution y est intégrée pour fournir une protection avancée et continue des actifs numériques.

1.3.4.1 Fondamentaux des Centres d’Opérations de Sécurité

Le Centre d’Opérations de Sécurité (SOC) agit comme le cœur de renseignement et le système nerveux central de la défense en cybersécurité d’une organisation. Composé d’une équipe spécialisée et d’une installation dédiée, il est chargé de surveiller, détecter, analyser et répondre activement aux menaces et incidents de sécurité. Il peut être imaginé comme un centre de commandement opérationnel 24h/24, 7j/7, protégeant constamment les actifs numériques.

1.3.4.2 Composants des SOC

Sur le champ de bataille numérique, les Centres d’Opérations de Sécurité se dressent comme des forteresses bastionnées, armés d’un arsenal puissant d’outils et de méthodologies pour repousser les agresseurs cybernétiques. Ils reposent sur trois piliers fondamentaux^[1] :

1. Le personnel :

C’est une équipe variée, semblable à un orchestre bien coordonné, qui joue un rôle crucial dans la lutte contre les menaces cybernétiques. Cette équipe inclut :

- Analystes de sécurité : qui surveillent les outils de sécurité, analysent les alertes, enquêtent sur les menaces et coordonnent les réponses aux incidents.
- Spécialistes de l'intelligence sur les menaces : qui suivent les tendances et les évolutions de la cybercriminalité, apportant des informations précieuses à l'équipe du SOC.
- Intervenants en cas d'incident : ce sont des professionnels qualifiés qui dirigent les efforts pour contenir et atténuer les incidents de sécurité.
- Ingénieurs de sécurité : qui maintiennent et optimisent les technologies et les infrastructures de sécurité utilisées par le SOC.

2. Les processus :

Au-delà des personnes qualifiées, le SOC fonctionne grâce à plusieurs processus qui orchestrent une réponse efficace à chaque menace cybernétique :

- Classification et Triage des événements : Classer rapidement chaque événement pour prioriser et escalader les incidents critiques qui nécessitent une investigation supplémentaire.
- Priorisation et Analyse : Se concentrer sur les attaques ciblant les actifs critiques pour maintenir la continuité des affaires après avoir identifié les menaces à fort impact.
- Remédiation et Récupération : Désinfecter les systèmes, restaurer les données et renforcer les défenses. Dans ce processus, les actifs et les opérations critiques sont prioritaires pour minimiser l'impact sur l'entreprise.
- Évaluation et Audit : Réaliser des évaluations périodiques des vulnérabilités et examiner en détail les résultats pour identifier les failles techniques.

3. Les Technologies et les outils :

Les SOC utilisent un ensemble de technologies et des outils pour assurer une sécurité continue, tels que :

- Gestion des Informations et des Événements de Sécurité (SIEM) : Agrège et analyse les journaux de divers outils de sécurité, offrant une visibilité en temps réel et des capacités de détection des menaces.
- Systèmes de Détection et de Prévention des Intrusions (IDS/IPS) : Surveillent le trafic réseau pour détecter les activités malveillantes et peuvent bloquer les attaques en temps réel.
- Détection et Réponse aux Incidents sur les Points de Terminaison (EDR) : Surveille les points d'extrémité pour détecter les signes de malwares ou autres menaces et permet une réponse rapide.
- Orchestration, Automatisation, et Réponse à la Sécurité (SOAR) : Automatise les tâches routinières et les workflows pour augmenter l'efficacité et les temps de réponse.

1.3.4.3 Fonctions Clés des SOC

Étant une unité centralisée responsable de la surveillance et de l'analyse de sécurité au sein d'une organisation, le SOC comprend plusieurs fonctions clés, telles que :

1. Gestion des Informations et des Événements de Sécurité :

Analyse des données de sécurité provenant de diverses sources, comme les journaux réseau, les systèmes de détection d'intrusion, et les scanners de vulnérabilités.

2. Renseignements sur les Menaces :

Recherche et analyse des acteurs de la menace, leurs tactiques, techniques et procédures (TTP), et le partage de ces informations avec le reste de l'équipe du SOC.

3. Réponse aux Incidents :

Identification des incidents de sécurité et communication avec les parties prenantes concernées.

4. Gestion des Vulnérabilités :

Identification, évaluation et atténuation des vulnérabilités des systèmes et réseaux de l'organisation.

5. Conformité :

Garantie de la conformité de l'organisation avec les réglementations et normes pertinentes, telles que le RGPD et le PCI-DSS.

6. Architecture et Ingénierie de la Sécurité :

Conception, implémentations et maintenance des contrôles de sécurité et l'infrastructure de l'organisation.

1.3.4.4 Rôles et Responsabilités des SOC

Les rôles fondamentaux au sein d'un SOC se composent de différents niveaux d'analystes SOC et de gestionnaires dédiés^[2].

1. Niveau 1 : Spécialiste du Triage :

Les analystes de niveau 1 sont principalement responsables de la collecte des données brutes et de l'examen des alarmes et des alertes. Ils doivent confirmer, évaluer ou ajuster la gravité des alertes et les enrichir avec des données pertinentes. Pour chaque alerte, le spécialiste du triage doit déterminer s'il s'agit d'une alerte justifiée ou d'un faux positif, étant donné que la fatigue d'alerte est un problème réel.

2. Niveau 2 : Répondant à l'Incident :

Au niveau 2, les analystes examinent les incidents de sécurité de haute priorité remontés par les spécialistes du triage et procèdent à une évaluation plus approfondie en utilisant des renseignements sur les menaces (indicateurs de compromission, règles mises à jour, etc.). Ils doivent comprendre l'étendue d'une attaque et identifier les systèmes affectés. Les données brutes de télémétrie des attaques collectées au niveau 1 sont transformées en renseignements sur les menaces exploitables à ce deuxième niveau.

3. Niveau 3 : Chasseur de Menaces :

Les analystes de niveau 3 sont les plus expérimentés au sein d'un SOC. Ils gèrent les incidents majeurs qui leur sont escaladés par les intervenants d'incidents. Ils effectuent également, ou supervisent au moins, les évaluations de vulnérabilité et les tests de pénétration pour identifier les vecteurs d'attaque possibles. Leur responsabilité la plus cruciale est d'identifier de manière proactive les menaces potentielles, les failles de sécurité et les vulnérabilités qui pourraient être méconnues. Ils doivent aussi recommander des moyens d'optimiser les outils de surveillance de sécurité déployés lorsqu'ils acquièrent une connaissance approfondie d'une menace potentielle. De plus, toute alerte de sécurité critique, renseignement sur les menaces et autres données de sécurité fournies par les analystes de niveaux 1 et 2 doivent être examinées à ce niveau.

Les responsables SOC supervisent l'équipe des opérations de sécurité. Ils fournissent des conseils techniques si nécessaire, mais surtout, ils assurent une gestion adéquate de l'équipe. Cela inclut l'embauche, la formation et l'évaluation des membres de l'équipe ; la création de processus ; l'évaluation des rapports d'incidents ; et le développement et la mise en œuvre de plans de communication de crise. Ils supervisent également les aspects financiers d'un SOC, soutiennent les audits de sécurité et rapportent au responsable de la sécurité de l'information (CISO) ou à un autre haut responsable de la direction.

1.3.4.5 Importance des SOC

Chaque organisation est constamment exposée aux menaces cybernétiques qui cherchent à exploiter ses faiblesses. Le Centre d'Opérations de Sécurité (SOC) intervient avec son équipe de sécurité dédiée, surveillant en permanence les activités suspectes et se préparant à repousser les attaques. Les avantages de disposer d'un SOC au sein d'une organisation incluent :

- Meilleure visibilité : Un SOC offre une vue centralisée de la posture de sécurité de l'organisation, permettant un suivi et une analyse plus efficaces des données de sécurité.
- Détection des menaces plus rapide : En utilisant une combinaison d'outils manuels et automatisés, un SOC peut détecter et répondre plus rapidement aux menaces.
- Réduction du temps de réponse aux incidents : Un SOC permet une réponse aux incidents plus coordonnée et efficace, ce qui peut aider à minimiser l'impact des incidents de sécurité.
- Efficacité accrue : Un SOC peut aider à automatiser de nombreuses tâches liées à la sécurité, telles que la collecte et l'analyse des journaux, ce qui peut aider à réduire la charge de travail du personnel IT et de sécurité.
- Meilleure conformité : Un SOC peut aider une organisation à se conformer aux normes et réglementations pertinentes, telles que le RGPD et le PCI-DSS.
- Meilleure gestion des menaces : Un SOC peut offrir des capacités de gestion proactive des menaces, ce qui peut aider à prévenir les incidents de sécurité avant qu'ils ne surviennent.

1.3.4.6 Utilisation des Solutions SOC Open-Source

Les solutions de sécurité traditionnelles sont souvent accompagnées de tarifs élevés, laissant de nombreuses organisations, notamment les petites et moyennes entreprises (PME), vulnérables. C'est ici que les solutions Open-Source interviennent. Voici où les outils open source brillent :

- **Rentabilité** : Pas de frais de licence élevés ni de dépendance à un fournisseur. Vous payez uniquement pour l'infrastructure et l'expertise dont vous avez besoin.
- **Personnalisation** : Adaptez et modifiez les outils selon vos besoins spécifiques et votre environnement.
- **Transparence** : Le code source ouvert permet un examen et une amélioration par la communauté, conduisant souvent à des outils plus sécurisés et fiables.
- **Communauté dynamique** : Bénéficiez des connaissances et du soutien d'une communauté dédiée de développeurs et de professionnels de la sécurité.

Chaque aspect d'un SOC dispose d'une offre open source. Certains sont des outils de niveau d'entrée désormais gérés par une entreprise de sécurité qui propose une version payante plus riche en fonctionnalités, tandis que d'autres sont des projets open source de longue date soutenus par une communauté dédiée :

- **Agrégation, recherche et visualisation** : Elasticsearch-Logstash-Kibana
- **Suivi des problèmes et des incidents** : TheHive, Bugzilla, Mantis, RedMine
- **Évaluation des vulnérabilités** : OpenVAS, Nessus
- **Outils de test de pénétration** : Kali Linux, Metasploit
- **Surveillance du réseau** : Suricata, Snort, Zeek
- **Détection et réponse aux incidents sur les points de terminaison** : OSSEC, Wazuh

Bien que les outils open source offrent un immense potentiel, ils nécessitent également une expertise technique pour leur mise en œuvre et leur maintenance. Construire et gérer un SOC open source peut représenter un défi pour de nombreuses organisations. Cependant, avec une approche et un soutien approprié, même les entreprises disposant de ressources limitées peuvent tirer parti de ces outils puissants pour sécuriser efficacement leurs actifs numériques. Cette capacité à adapter et à renforcer les outils de sécurité grâce à des ressources open source peut être encore améliorée par l'intégration de technologies avancées telles que l'Extended Detection and Response (XDR).

C'est dans ce contexte que notre solution intervient pour répondre à ces besoins spécifiques. Pour surmonter les limitations des solutions de sécurité traditionnelles, nous avons développé une solution de Détection et Réponse Étendues (XDR) basée sur des outils open source. Cette architecture XDR est conçue pour offrir une protection avancée et intégrée contre les menaces, en combinant divers composants spécialisés. Notre solution se distingue par sa capacité à fournir

une visibilité complète sur les incidents de sécurité à travers différents points de terminaison et le réseau, tout en assurant une réponse rapide et coordonnée aux menaces détectées. En intégrant ces outils, nous offrons une défense en profondeur qui améliore la détection des menaces, réduit les faux positifs et optimise l'efficacité opérationnelle de la sécurité informatique.

1.3.4.7 Composants de la Solution XDR

- **XDR (Extended Detection and Response)** est une solution complète qui fournit une vue unifiée et centralisée des menaces à travers divers points de terminaison, réseaux, et systèmes de sécurité. En combinant les capacités de détection et de réponse, l'XDR permet une analyse approfondie des incidents et une réponse automatisée. Dans notre architecture, il joue un rôle crucial en fournissant une détection avancée des menaces et une réponse coordonnée aux incidents en temps réel.
- **SIEM (Security Information and Event Management)** est une plateforme essentielle pour la collecte, la corrélation et l'analyse des journaux et événements de sécurité provenant de diverses sources au sein de l'infrastructure informatique. En centralisant les données, le SIEM permet une détection rapide des menaces et une analyse approfondie des incidents de sécurité, assurant ainsi une détection des menaces en temps réel et une gestion centralisée des journaux de sécurité.
- **NIDS (Network-based Intrusion Detection System)** analyse les protocoles et le trafic réseau pour détecter des comportements anormaux et des attaques sophistiquées. Ce système de surveillance offre une visibilité détaillée sur les activités du réseau, permettant une détection proactive des menaces et fournissant une analyse approfondie des protocoles réseau pour identifier les menaces potentielles.
- **SOAR (Security Orchestration, Automation, and Response)** est conçu pour automatiser et orchestrer les processus de réponse aux incidents. Il permet aux équipes de sécurité de gérer efficacement les alertes et incidents en automatisant les tâches répétitives et en coordonnant les actions de réponse, améliorant ainsi l'efficacité de la réponse aux incidents en automatisant et en orchestrant les actions de sécurité.
- **Threat Intelligence Platform** facilite le partage et l'analyse des informations sur les menaces. En collectant des données de différentes sources, elle fournit une vue globale des menaces actuelles, permettant aux équipes de sécurité de rester informées et de réagir rapidement. Cela améliore la détection des menaces en partageant des informations actualisées sur les menaces.
- **Pare-feu (Firewall)** est un dispositif de sécurité réseau qui contrôle le trafic entrant et sortant selon des règles de sécurité prédéfinies. En agissant comme une barrière protectrice entre le réseau interne sécurisé et les réseaux externes non sécurisés, le pare-feu protège le réseau en filtrant le trafic et en bloquant les accès non autorisés.

- **Load Balancer** distribue le trafic et les tâches sur plusieurs serveurs pour optimiser l'utilisation des ressources, garantir la performance et assurer la disponibilité des services. Il joue un rôle essentiel dans l'architecture en assurant la répartition efficace des charges de travail, augmentant la résilience et la performance du système.

En intégrant ces composants, notre solution XDR offre une architecture robuste et évolutive, capable de détecter et de répondre aux menaces en temps réel. Elle minimise les faux positifs, fournit une protection avancée, et améliore l'efficacité opérationnelle de l'infrastructure informatique de l'entreprise.

1.4 Conclusion

Après avoir présenté l'entreprise et exploré ses systèmes de sécurité en place, nous avons identifié les limitations de ces technologies face aux cybermenaces actuelles et proposé notre solution XDR. Dans le chapitre suivant, nous comparerons les différents composants disponibles sur le marché, puis nous expliquerons les raisons de notre choix des composants spécifiques pour notre architecture de sécurité renforcée.

Chapitre 2

Étude comparative

2.1 Introduction

Ce chapitre est consacré à une étude comparative des différents composants essentiels à l'implémentation de notre solution de Détection et Réponse Étendues (XDR). Nous évaluerons diverses options pour chaque type de composant afin d'identifier les solutions les plus adaptées à nos exigences spécifiques. Cette analyse approfondie nous permettra de sélectionner les composants les plus pertinents pour renforcer notre architecture de sécurité, tout en justifiant nos choix stratégiques.

2.2 Étude Comparative des Composants

Afin d'évaluer l'efficacité et la pertinence des différentes solutions XDR disponibles sur le marché, on a mené une analyse comparative approfondie en termes de fonctionnalités, d'intégration et de coûts.

2.2.1 XDR (Extended Detection and Response)

L'Extended Detection and Response (XDR) est une solution intégrée conçue pour offrir une protection avancée en unifiant la détection et la réponse aux menaces à travers divers points de terminaison et réseaux.

— Wazuh

Wazuh est une plateforme open source qui intègre des fonctionnalités XDR, offrant une surveillance continue des menaces, la gestion des journaux et des capacités de réponse aux incidents. Wazuh se distingue par sa flexibilité et sa capacité à s'intégrer facilement avec d'autres outils de sécurité. Il offre une solution économique pour les organisations cherchant à déployer une architecture XDR sans engager de coûts élevés^[3].



FIGURE 2.1 – XDR Wazuh

— **Microsoft Defender XDR**

Microsoft Defender XDR est une solution commerciale qui propose une protection complète et intégrée contre les menaces. Il est conçu pour offrir des capacités avancées de détection et de réponse, avec une intégration étroite avec l'écosystème Microsoft. Cette solution est idéale pour les entreprises déjà investies dans les produits Microsoft, offrant une interface utilisateur intuitive et un support technique robuste^[4].



FIGURE 2.2 – Microsoft Defender XDR

— **Palo Alto Networks Cortex XDR**

Cortex XDR de Palo Alto Networks est une solution avancée qui combine l'analyse comportementale et l'automatisation de la réponse aux incidents. Elle intègre divers produits de sécurité Palo Alto, offrant une protection robuste et une interface utilisateur conviviale. Cortex XDR est particulièrement adapté aux organisations nécessitant des capacités de détection et de réponse de pointe^[1].



FIGURE 2.3 – Palo Alto Networks Cortex XDR

En comparant ces trois solutions, Wazuh se distingue par son modèle open source, offrant une flexibilité et une rentabilité significatives pour les organisations à budget limité. Bien que Microsoft Defender XDR et Palo Alto Networks Cortex XDR offrent des fonctionnalités avancées, leurs coûts élevés peuvent être prohibitifs. Wazuh, avec ses capacités intégrées de surveillance et de réponse, présente un excellent compromis entre coût, flexibilité et fonctionnalités, ce qui en fait un choix judicieux pour notre architecture XDR.

2.2.2 SIEM (Security Information and Event Management)

Les systèmes SIEM jouent un rôle crucial dans la collecte, l'analyse et la corrélation des journaux de sécurité provenant de diverses sources. Ils offrent une visibilité en temps réel sur les événements de sécurité et aident à détecter et à répondre rapidement aux incidents.

— Wazuh

Wazuh est une plateforme open source qui offre des fonctionnalités SIEM. Elle est conçue pour détecter les intrusions, surveiller l'intégrité des fichiers, alerter sur les anomalies et fournir des informations sur les vulnérabilités. Wazuh est flexible, évolutif et bénéficie d'un fort soutien de la communauté, ce qui en fait une solution économique et efficace pour les organisations de toutes tailles^[3].



FIGURE 2.4 – SIEM Wazuh

— Splunk

Splunk est une solution commerciale de gestion des journaux et de SIEM très populaire. Elle est connue pour ses puissantes capacités d'analyse et de visualisation des données. Splunk offre une interface utilisateur intuitive, des fonctionnalités de tableau de bord avancées, et un support client de haute qualité. Son écosystème d'applications et d'intégrations tierces est très développé, ce qui en fait une option robuste pour les grandes entreprises.^[5]



FIGURE 2.5 – Splunk

— QRadar (IBM Security QRadar)

QRadar est une solution SIEM commerciale développée par IBM. Elle offre des capacités avancées de détection des menaces et de gestion des incidents. QRadar excelle dans l'analyse comportementale et l'intégration avec d'autres produits de sécurité. Elle est soutenue par un support technique et des services professionnels de haute qualité, ce qui la rend idéale pour les grandes organisations nécessitant une solution SIEM avancée^[6].



FIGURE 2.6 – QRadar

En comparant ces trois solutions, Wazuh se distingue par son modèle open source, qui offre une flexibilité et une rentabilité significatives pour les organisations à budget limité. Bien que Splunk et QRadar offrent des fonctionnalités plus avancées et un support technique robuste, leurs coûts élevés peuvent être prohibitifs. Wazuh, malgré ses exigences techniques, présente un excellent compromis entre coût, flexibilité et fonctionnalités, ce qui en fait un choix judicieux pour notre architecture XDR.

2.2.3 NIDS (Network-based Intrusion Detection System)

Les systèmes de détection d'intrusion basés sur le réseau (NIDS) surveillent le trafic réseau pour détecter les menaces potentielles. Voici une comparaison de trois NIDS reconnus :

— **Suricata**

Suricata est un NIDS open source puissant capable de surveiller le trafic réseau en temps réel et d'analyser les protocoles. Il se distingue par ses performances élevées et sa capacité de multithreading, permettant de traiter de grands volumes de trafic. Suricata offre également un large soutien de la communauté et de nombreuses intégrations avec d'autres outils de sécurité^[7].



FIGURE 2.7 – Logo Suricata

— **Zeek (anciennement Bro)**

Zeek est un NIDS open source axé sur l'analyse en profondeur des protocoles réseau et la surveillance en temps réel. Il offre une capacité d'analyse détaillée des protocoles et est extensible grâce à un langage de script puissant. Zeek bénéficie également d'un bon support communautaire et d'une documentation abondante, ce qui le rend adapté pour des environnements nécessitant une analyse détaillée du trafic réseau^[8].



FIGURE 2.8 – Logo Zeek

— **Snort**

Snort est l'un des NIDS open source les plus populaires et les plus largement utilisés. Il offre une détection basée sur les signatures et est facile à configurer et à déployer. Snort est soutenu par une large communauté et dispose d'une vaste base de signatures de détection, ce qui en fait une solution efficace pour des environnements nécessitant une détection rapide et fiable des menaces^[9].



FIGURE 2.9 – Logo Snort

Suricata est choisi pour sa capacité complémentaire et robuste en tant que NIDS. Suricata offre des performances élevées et une capacité de multithreading, ce qui est crucial pour traiter de grands volumes de trafic réseau. Bien que Zeek et Snort aient leurs propres avantages, Suricata est privilégié pour notre architecture en raison de ses capacités exceptionnelles de détection et de traitement des menaces à grande échelle. L'intégration de Suricata offre une solution complète et performante pour notre architecture de détection d'intrusion basée sur le réseau.

2.2.4 SOAR (Security Orchestration, Automation, and Response)

Les solutions SOAR permettent d'automatiser et d'orchestrer les réponses aux incidents de sécurité, augmentant ainsi l'efficacité opérationnelle. Voici une comparaison de trois solutions SOAR reconnues :

- **Cortex XSOAR (anciennement Demisto)**

Cortex XSOAR est une solution SOAR de Palo Alto Networks qui offre une plateforme complète pour l'orchestration et l'automatisation de la sécurité. Elle se distingue par son interface utilisateur intuitive, sa large bibliothèque de playbooks prédéfinis, et son intégration facile avec d'autres outils de sécurité. Cortex XSOAR est soutenu par un fort support technique et une communauté active, offrant une interface utilisateur intuitive, une large bibliothèque de playbooks prédéfinis et une intégration facile avec d'autres outils de sécurité^[10].



FIGURE 2.10 – Logo Cortex XSOAR

— Splunk Phantom

Splunk Phantom est une solution SOAR qui se distingue par ses puissantes capacités d'automatisation et d'intégration. Elle offre une intégration transparente avec Splunk SIEM et dispose d'un large éventail de connecteurs et d'intégrations. Phantom propose une interface utilisateur conviviale et personnalisable, ainsi qu'un support technique robuste et une documentation complète, rendant son utilisation et sa configuration très flexibles et puissantes^[11].



FIGURE 2.11 – Logo Splunk Phantom

— Cortex

Cortex est une plateforme open source qui se concentre sur l'automatisation et la standardisation de l'analyse des artefacts numériques et des événements de sécurité. Elle permet d'enrichir les incidents avec des informations provenant de diverses sources, facilitant ainsi l'analyse et la prise de décision. Cortex est particulièrement efficace lorsqu'il est intégré avec TheHive, une plateforme de gestion des incidents. Sa nature open source, sa flexibilité et sa personnalisation élevée, ainsi que son intégration étroite avec TheHive en font un outil précieux soutenu par une forte communauté de support et de développement.



FIGURE 2.12 – Logo Cortex

Cortex est choisi pour sa nature open source et sa capacité à s'intégrer étroitement avec TheHive, ce qui le rend particulièrement adapté pour les organisations cherchant à enrichir les incidents de sécurité sans engager de coûts élevés. Bien que Cortex XSOAR et Splunk Phantom offrent des fonctionnalités avancées et un support technique solide, leurs coûts élevés et leur complexité peuvent être des obstacles. Cortex, avec sa simplicité et son coût nul, s'aligne parfaitement avec notre stratégie de déploiement d'une solution SOAR économique et efficace.

2.2.5 Threat Intelligence Platform

Les plateformes de renseignement sur les menaces (Threat Intelligence Platform) sont essentielles pour collecter, analyser et diffuser des informations sur les menaces potentielles. Voici une comparaison de trois solutions reconnues :

— **MISP (Malware Information Sharing Platform)**

MISP est une plateforme open source pour le partage d'informations sur les menaces, largement utilisée par les communautés de sécurité. Elle se distingue par sa nature collaborative et ses capacités avancées de partage et d'analyse des menaces. MISP s'intègre facilement avec de nombreux outils de sécurité et bénéficie d'une large communauté de soutien, ce qui en fait une solution économique et efficace pour la gestion du renseignement sur les menaces^[12].



FIGURE 2.13 – Logo MISP

— **Recorded Future**

Recorded Future est une solution commerciale offrant des capacités de renseignement sur les menaces en temps réel. Elle se distingue par son analyse en temps réel des menaces et son intégration avec divers outils de sécurité. Recorded Future propose une interface utilisateur intuitive et personnalisable, ainsi qu'un support client de haute qualité, ce qui en fait une solution robuste pour les grandes organisations^[13].



FIGURE 2.14 – Logo Recorded Future

— **ThreatConnect**

ThreatConnect est une plateforme de renseignement sur les menaces offrant des capacités avancées d'analyse et de collaboration. Elle se distingue par son interface utilisateur intuitive et personnalisable, ainsi que par ses capacités avancées de collaboration et de partage. ThreatConnect s'intègre avec divers outils de sécurité et est soutenue par un support technique robuste, ce qui en fait une solution idéale pour les organisations nécessitant une gestion avancée des menaces^[14].



FIGURE 2.15 – Logo ThreatConnect

MISP est choisi pour sa nature open source, ses capacités de partage collaboratif et son intégration avec d'autres outils de sécurité. Bien que Recorded Future et ThreatConnect offrent des fonctionnalités avancées et un support de haute qualité, leurs coûts élevés peuvent être des obstacles pour les organisations à budget limité. MISP, avec ses fonctionnalités robustes et sa communauté active, est le choix optimal pour notre architecture de renseignement sur les menaces.

2.2.6 Pare-feu (Firewall)

Les pare-feux sont essentiels pour contrôler le trafic réseau entrant et sortant en fonction de règles de sécurité prédéfinies. Voici une comparaison de trois pare-feux reconnus :

— PfSense

pfSense est un pare-feu open source basé sur FreeBSD, offrant des fonctionnalités avancées de routage et de filtrage. Il se distingue par son interface utilisateur intuitive et personnalisable, ainsi que par sa large gamme de fonctionnalités de sécurité. pfSense bénéficie d'une forte communauté de support, ce qui en fait une solution économique et efficace pour les organisations de toutes tailles^[15].



FIGURE 2.16 – Logo Pfsense

— Cisco ASA (Adaptive Security Appliance)

Cisco ASA est une solution de pare-feu commerciale largement utilisée. Elle offre des fonctionnalités avancées de sécurité et de gestion, ainsi qu'une intégration avec d'autres produits Cisco. Cisco ASA est soutenue par un support technique et des services professionnels de haute qualité, ce qui la rend idéale pour les grandes entreprises nécessitant une solution de pare-feu robuste et fiable^[16].



FIGURE 2.17 – Logo Cisco ASA

— Fortinet FortiGate

Fortinet FortiGate est une solution de pare-feu commerciale offrant des capacités avancées de sécurité réseau. Elle se distingue par ses fonctionnalités de sécurité évolutives, son interface utilisateur conviviale et personnalisable, et son intégration avec d'autres produits Fortinet. FortiGate est soutenue par un support technique robuste, ce qui en fait une solution de pare-feu efficace pour les grandes organisations^[17].



FIGURE 2.18 – Logo Fortinet FortiGate

pfSense est choisi pour sa nature open source, ses fonctionnalités robustes et sa flexibilité, ce qui le rend adapté pour les organisations cherchant une solution de pare-feu économique et efficace. Bien que Cisco ASA et Fortinet FortiGate offrent des fonctionnalités avancées et un support technique solide, leurs coûts élevés peuvent être des obstacles. pfSense, avec son modèle open source et son support communautaire, est le choix optimal pour notre architecture de pare-feu.

2.3 Load Balancer

Les load balancers (équilibrage de charge) sont essentiels pour distribuer le trafic réseau et les tâches sur plusieurs serveurs afin d'optimiser l'utilisation des ressources, garantir la performance et assurer la disponibilité des services. Voici une comparaison de trois load balancers reconnus :

— HAProxy

HAProxy est une solution open source de load balancing qui est largement utilisée pour sa

fiabilité et ses performances élevées. Il est capable de distribuer efficacement les charges de travail sur plusieurs serveurs, offrant une disponibilité élevée et une tolérance aux pannes. HAProxy supporte une large gamme de protocoles et peut être configuré pour des scénarios de load balancing complexes^[18].



FIGURE 2.19 – Logo HAProxy

— Nginx

Nginx est une solution open source qui sert à la fois de serveur web et de load balancer. Il est reconnu pour sa capacité à gérer un grand nombre de connexions simultanées avec une faible utilisation des ressources. Nginx offre des fonctionnalités avancées de load balancing, notamment la répartition de la charge en fonction du poids des serveurs et la gestion de la redondance^[19].



FIGURE 2.20 – Logo Nginx

— F5 BIG-IP

F5 BIG-IP est une solution commerciale de load balancing offrant des fonctionnalités avancées pour la gestion du trafic et la sécurité des applications. Elle propose une répartition intelligente des charges, une sécurité renforcée et une gestion simplifiée des applications. F5 BIG-IP est adaptée aux grandes entreprises nécessitant des solutions de load balancing robustes et évolutives^[20].



FIGURE 2.21 – Logo F5 BIG-IP

Nginx est choisi pour sa nature open source, ses performances élevées et sa capacité à gérer un grand nombre de connexions simultanées avec une faible utilisation des ressources. Nginx offre des fonctionnalités avancées de load balancing, notamment la répartition de la charge en fonction du poids des serveurs et la gestion de la redondance. Bien que HAProxy et F5 BIG-IP offrent également des fonctionnalités robustes, Nginx se distingue par sa flexibilité et sa capacité à servir à la fois de serveur web et de load balancer, ce qui le rend particulièrement adapté pour notre architecture. Son modèle open source et son support communautaire en font une solution économique et efficace, optimisant l'utilisation des ressources tout en assurant la disponibilité et la performance des services.

Pour résumer, chaque composant de notre architecture XDR a été soigneusement choisi en tenant compte de divers critères, tels que la performance, la flexibilité, les coûts et la facilité d'intégration. En comparant les options disponibles, nous avons pu sélectionner des outils qui non seulement répondent à nos besoins spécifiques, mais qui s'alignent également avec notre stratégie de sécurité globale. Ces choix stratégiques permettent de construire une architecture robuste et efficace, prête à détecter et répondre aux menaces de manière proactive.

2.4 Conclusion

Dans ce chapitre, nous avons analysé et comparé les différentes solutions disponibles pour chaque composant de notre architecture XDR, nous permettant d'identifier les outils les plus adaptés à nos besoins spécifiques. Dans le chapitre suivant, nous détaillerons notre architecture de test et sa configuration.

Chapitre 3

Implémentation

3.1 Introduction

Ce chapitre se concentrera sur l'implémentation de notre solution XDR. On détaillera la configuration des différents composants, la connexion des nœuds, et les étapes nécessaires pour intégrer les outils et technologies sélectionnés dans une architecture fluide. L'objectif est de s'assurer que chaque élément de notre solution fonctionne de manière harmonieuse et efficace, garantissant ainsi une sécurité optimale et une réponse rapide aux incidents.

3.2 Architecture

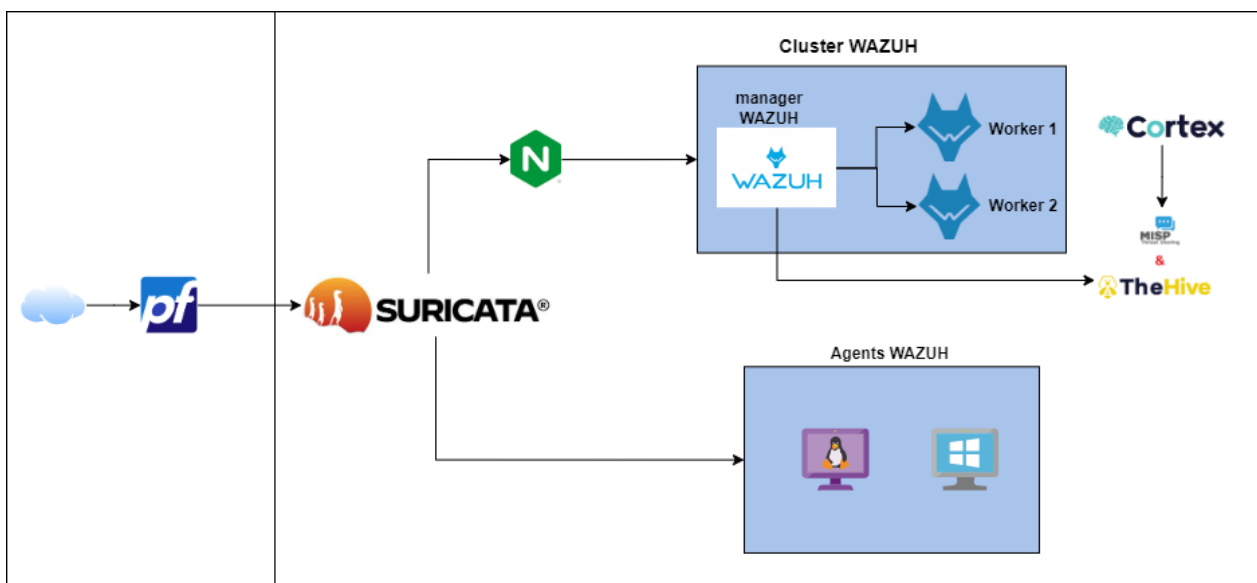


FIGURE 3.1 – Architecture

Dans cette section, on décrira l'architecture de notre solution XDR en détaillant les composants utilisés et leur disposition dans le réseau. On expliquera comment chaque composant contribue à la sécurité globale de l'infrastructure, comment ils interagissent entre eux et les bénéfices de leur intégration dans une solution XDR. Cette analyse fournira une vue d'ensemble

claire de la manière dont les différents outils et technologies sont orchestrés pour offrir une surveillance et une réponse efficace aux menaces.

3.2.1 Analyse de l'Architecture

L'architecture de notre solution XDR repose sur une intégration harmonieuse de plusieurs composants essentiels. Chaque composant joue un rôle spécifique dans la détection, l'analyse et la réponse aux menaces de sécurité. Ci-dessous, on examine en détail les fonctions et les interactions de ces composants dans notre réseau.^[3]

— Agents Wazuh

installés sur les machines des utilisateurs (Windows et Linux), ces agents surveillent les activités des endpoints et collectent des logs de sécurité. Les logs sont envoyés au cluster Wazuh via un Load Balancer, garantissant une distribution équilibrée des requêtes. Les agents jouent un rôle crucial en détectant les événements de sécurité localement et en relayant ces informations au serveur central pour une analyse plus approfondie.

— Suricata

est déployé pour capturer et analyser le trafic réseau. En tant que système de détection d'intrusions réseau (NIDS), Suricata inspecte le trafic en temps réel, détectant les anomalies et les comportements malveillants. Il envoie ensuite les alertes pertinentes au cluster Wazuh pour une action immédiate.

— Cluster Wazuh

Le cluster comprend le Wazuh Manager et deux Workers. Le Wazuh Manager est responsable de la gestion centralisée des logs, de la configuration des agents et de l'émission des alertes. Les Workers assurent la distribution de charge, augmentant la performance et la disponibilité du système. Cette configuration garantit que le traitement des logs et la génération des alertes sont effectués de manière efficace et sans interruption.

— MISP + The Hive + Cortex

Ces outils sont intégrés pour enrichir les alertes et orchestrer la réponse aux incidents. MISP (Malware Information Sharing Platform) fournit des renseignements sur les menaces, The Hive gère les cas d'incidents et Cortex automatise l'analyse et la réponse. Ensemble, ils offrent une analyse approfondie des incidents, facilitent la collaboration et assurent une réponse coordonnée et rapide aux menaces détectées.

3.2.2 Configuration d'un réseau virtuel sur Google Cloud

Un réseau virtuel sur Google Cloud Platform (GCP) fonctionne de manière similaire à un réseau traditionnel que vous pourriez exploiter vous-même dans un centre de données. Il offre cependant des avantages supplémentaires tels que l'évolutivité, la disponibilité et l'isolement. Pour la mise en place de notre solution, on a créé un seul réseau virtuel (VPC) avec une plage d'adresses IP 192.168.0.0/16 pour inclure tous les composants. Cette configuration

permet une gestion simplifiée et une communication fluide entre les différentes machines. La figure 3.2 illustre le réseau XDR configuré et le sous-réseau Wazuh avec la plage d’adresses IP 192.168.0.0/16

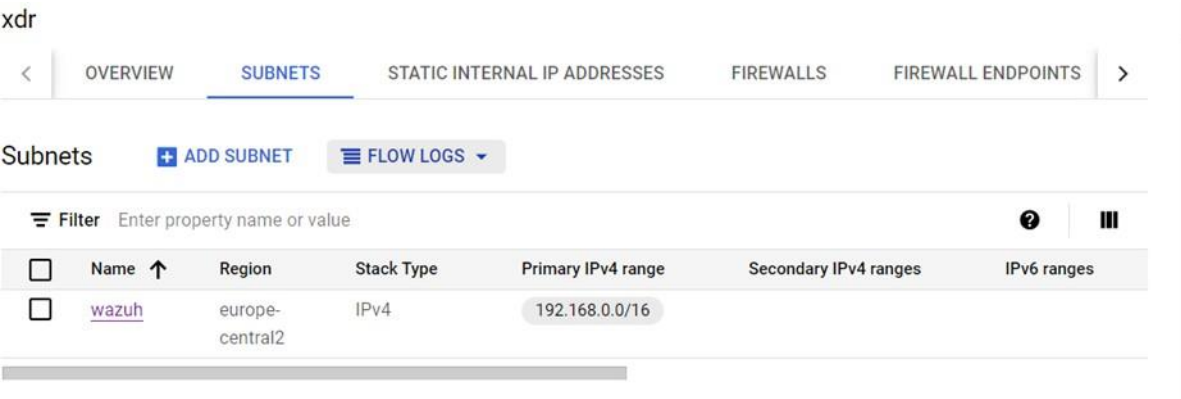


FIGURE 3.2 – Réseau

3.2.2.1 Composants et Adresses IP

TABLE 3.1 – Les interfaces de PfSense

Interface	Adresse IP
Vtneto (default)	10.186.0.9
Vtnet1 (Wazuh)	192.168.0.38

TABLE 3.2 – Table d’adressage

Composant	Adresse IP
Wazuh Manager	192.168.0.2
Wazuh Worker 1	192.168.0.3
Wazuh Worker 2	192.168.0.31
Suricata	192.168.0.9
Cortex	192.168.0.36
TheHive + MISP	192.168.0.26
Load Balancer	192.168.0.5
Agent1	192.168.0.4
Agent2	192.168.0.56

Ce tableau permet de visualiser clairement les adresses IP attribuées à chaque composant dans leurs réseaux respectifs, facilitant ainsi la gestion et la configuration de l’infrastructure.

3.2.2.2 Machines Virtuelles

On a utilisé Google Cloud Platform (GCP) pour déployer les machines virtuelles nécessaires à notre solution. Le tableau ci-dessous montre les détails des machines virtuelles et des configurations réseau utilisées

TABLE 3.3 – Les machines

Machine	Type de machine	Système d'Exploitation	Stockage
Wazuh Manager	2 vCPUs, 4 GB RAM	Ubuntu 20.04 LTS	Disque persistant 30 GB
Wazuh Worker 1	2 vCPUs, 4 GB RAM	Ubuntu 20.04 LTS	Disque persistant 30 GB
Wazuh Worker 2	2 vCPUs, 4 GB RAM	Ubuntu 20.04 LTS	Disque persistant 30 GB
PfSense	4 vCPUs, 2 GB RAM		Disque persistant 10 GB
Suricata	2 vCPUs, 4 GB RAM	Ubuntu 20.04 LTS	Disque persistant 30 GB
Cortex	4 vCPUs, 16 GB RAM	Ubuntu 20.04 LTS	Disque persistant 20 GB
TheHive + MISP	4 vCPUs, 16 GB RAM	Ubuntu 20.04 LTS	Disque persistant 35 GB
Load Balancer	2 vCPUs, 4 GB RAM	Ubuntu 20.04 LTS	Disque persistant 30 GB
Agent1	2 vCPUs, 4 GB RAM	Ubuntu 20.04 LTS	Disque persistant 15 GB
Agent2	2 vCPUs, 8 GB RAM	Windows Server 2019	Disque persistant 50 GB

Chaque machine virtuelle a été dotée des ressources nécessaires pour garantir une performance optimale et une capacité de stockage suffisante. En précisant les configurations des machines virtuelles, des réseaux et des adresses IP attribuées, on s'assure que chaque composant de notre architecture XDR est bien configuré et prêt à fonctionner efficacement.

3.2.3 Installation et Configuration des Composants

3.2.3.1 Configuration de Cluster Wazuh

Le cluster Wazuh joue un rôle crucial dans notre architecture XDR en centralisant la gestion des logs et des alertes de sécurité. L'installation du gestionnaire Wazuh (manager) ainsi que des workers permet d'assurer une répartition efficace des tâches et de garantir une haute disponibilité du système. Cette configuration robuste permet une surveillance continue et une réponse rapide aux incidents de sécurité.

La commande “`sudo systemctl status wazuh-manager`” permet de vérifier l'état du service Wazuh Manager. L'état “active (running)” confirme que le gestionnaire Wazuh est correctement installé et fonctionne.

```

rabejberbi031@master:~$ sudo systemctl status wazuh-manager.service
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enable
   Active: active (running) since Fri 2024-04-26 12:44:54 UTC; 11min ago
     Tasks: 116 (limit: 4680)
    Memory: 249.6M

```

FIGURE 3.3 – Vérification du Gestionnaire Wazuh

Les mêmes étapes d'installation sont appliquées aux workers Wazuh pour assurer qu'ils sont correctement intégrés au cluster. Les détails complets de l'installation des workers sont disponibles dans l'annexe.

Pour configurer les nœuds du cluster Wazuh, on a modifié le fichier de configuration `/var/ossec/etc/ossec.conf` sur chaque nœud. Une clé sécurisée et partagée est utilisée pour sécuriser la communication entre les nœuds du cluster, assurant ainsi une connexion fiable et sécurisée. Le

fichier de configuration sur le gestionnaire définit les paramètres du cluster, tels que le nom du cluster, le type de nœud (master), la clé de sécurité, le port et l'adresse de liaison.

```
<cluster>
  <name>wazuh</name>
  <node_name>master-node</node_name>
  <node_type>master</node_type>
  <key>bf1d783e690023c2d95899f023d520ba</key>
  <port>1516</port>
  <bind_addr>0.0.0.0</bind_addr>
  <nodes>
    <node>192.168.10.2</node>
  </nodes>
  <hidden>no</hidden>
  <disabled>no</disabled>
</cluster>
```

FIGURE 3.4 – Configuration du Fichier de Configuration sur le Gestionnaire

Le fichier de configuration du worker reprend des paramètres similaires à ceux du gestionnaire, avec les différences suivantes :

- **Type de Nœud** : Déclaré comme "worker" pour indiquer son rôle dans le cluster.
- **Nom de Nœud** : Identifie le nœud spécifique en tant que "worker2".

Cette uniformité dans les paramètres de configuration garantit une communication sécurisée et cohérente au sein du cluster.

```
<cluster>
  <name>wazuh</name>
  <node_name>worker2</node_name>
  <node_type>worker</node_type>
  <key>bf1d783e690023c2d95899f023d520ba</key>
  <port>1516</port>
  <bind_addr>0.0.0.0</bind_addr>
  <nodes>
    <node>192.168.10.2</node>
  </nodes>
  <hidden>no</hidden>
  <disabled>no</disabled>
</cluster>
```

FIGURE 3.5 – Configuration du Fichier de Configuration sur le Worker

Pour tester le cluster Wazuh, on a utilisé une commande permettant de vérifier l'état et la connectivité des nœuds du cluster. Cette commande affiche les nœuds actifs avec leurs adresses IP et leurs versions, confirmant ainsi que le cluster est correctement configuré et que les nœuds communiquent efficacement.

```

worker2      worker  4.7.4    192.168.0.31
rabebjerbi031@master:~$ sudo /var/ossec/bin/cluster_control -l
NAME          TYPE      VERSION  ADDRESS
master-node   master    4.7.4    192.168.10.2
worker2       worker    4.7.4    192.168.0.31
worker1-node  worker    4.7.4    192.168.0.3
rabebjerbi031@master:~$

```

FIGURE 3.6 – Test du Cluster

3.2.3.2 Installation et Configuration de Nginx pour le Cluster Wazuh

Afin de garantir une répartition optimale du trafic entre les différents nœuds de notre cluster Wazuh, on a choisi d'installer et de configurer Nginx en tant qu'équilibreur de charge. Cette configuration permet d'assurer que les requêtes sont distribuées de manière uniforme entre les nœuds, améliorant ainsi la performance et la disponibilité du système. La figure 3.7 confirme que Nginx est correctement installé et opérationnel, prêt à équilibrer la charge du trafic entre les différents nœuds du cluster Wazuh.

```

rabebjerbi031@loadbalancer:~$ sudo systemctl enable nginx
Synchronizing state of nginx.service with SysV service script with /lib/systemd/systemd-sysv-
install.
Executing: /lib/systemd/systemd-sysv-install enable nginx
rabebjerbi031@loadbalancer:~$ sudo systemctl start nginx
rabebjerbi031@loadbalancer:~$ sudo systemctl status nginx
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/lib/systemd/system/nginx.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2024-04-26 13:26:17 UTC; 1min 52s ago

```

FIGURE 3.7 – Activation de Nginx

Pour assurer une distribution équilibrée du trafic entre le gestionnaire et les workers du cluster Wazuh, nous avons configuré Nginx comme équilibreur de charge en modifiant le fichier de configuration “/etc/nginx/nginx.conf.”.

```

}
stream {
    # Group for agent registration
    upstream wazuh_master {
        server 192.168.10.2:1515; # Wazuh manager server for agent registration
    }

    # Group for agent traffic
    upstream wazuh_cluster {
        hash $remote_addr consistent; # Load balancing using the client's IP address for consistency
        server 192.168.10.2:1514; # Manager node for reporting
        server 192.168.0.3:1514; # Worker node for reporting
        server 192.168.0.31:1514; # Worker node for reporting
    }

    # Server for agent registration on port 1515
    server {
        listen 1515;
        proxy_pass wazuh_master; # Passes traffic to the wazuh_master upstream
    }

    # Server for agent reporting on port 1514
    server {
        listen 1514;
        proxy_pass wazuh_cluster; # Passes traffic to the wazuh_cluster upstream
    }
}

```

FIGURE 3.8 – Configuration de Nginx

Le fichier de configuration de Nginx contient les sections suivantes :

- **Groupes pour l'Enregistrement des Agents** : Définissent les serveurs responsables de l'enregistrement des agents.
- **Groupes pour le Trafic des Agents** : Spécifient les serveurs de reporting pour la répartition de la charge.
- **Serveur pour l'Enregistrement des Agents** : Configure l'écoute sur le port 1515 et redirige vers le groupe wazuh_master.
- **Serveur pour le Reporting des Agents** : Configure l'écoute sur le port 1514 et redirige vers le groupe wazuh_cluster.

Cette configuration permet de gérer efficacement le trafic des agents, assurant ainsi une performance optimale du cluster Wazuh.

3.2.3.3 Installation et Configuration de MISP

MISP permet le partage de renseignements sur les menaces. Son intégration avec Wazuh et TheHive enrichit notre capacité de détection et de réponse, améliorant ainsi la sécurité globale de notre système. Pour installer MISP, on a téléchargé le script d'installation à l'aide de la commande "wget", puis exécuté ce script pour configurer MISP.^[?]

```
rabebjerbi031@vm:~$ sudo wget --no-cache -O /tmp/INSTALL.sh https://raw.githubusercontent.com/MISP/MISP/2.4/INSTALL/INSTALL.sh
--2024-05-14 16:56:18-- https://raw.githubusercontent.com/MISP/MISP/2.4/INSTALL/INSTALL.sh
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.11
```

FIGURE 3.9 – Installation de MISP

Cette commande permet de récupérer le script d'installation depuis le dépôt GitHub de MISP et de l'exécuter pour procéder à l'installation complète de MISP sur le système.

Après l'installation, on a créé une organisation dans MISP pour structurer la gestion des utilisateurs et des données de manière organisée.

Organisation pfe-soc	
ID	2
UUID	a54676c6-9241-4556-8929-80376a29e29d
Local or remote	Local
Created by	admin@admin.test
Creation time	2024-05-14 17:09:55
Last modified	2024-05-14 17:09:55
Nationality	Tunisia
Sector	Soc
Organisation type	Open Source

Members Events Sharing Groups

FIGURE 3.10 – Création d'une Organisation

La figure 3.10 montre les détails de l'organisation créée, notamment l'ID, l'UUID, le créateur, et les informations de contact. L'organisation "pfe-soc" est configurée pour fonctionner localement et est définie comme une organisation open source opérant dans le secteur SOC.

Ensuite, on a créé un utilisateur administrateur pour gérer les opérations et la configuration dans MISP. La figure 3.11 montre le formulaire de création d'un utilisateur dans MISP. On a spécifié l'adresse e-mail, le mot de passe, l'organisation associée, et le rôle de l'utilisateur (admin). Cet utilisateur administrateur aura les droits nécessaires pour configurer et gérer les divers aspects de MISP.

Admin Add User

Email
admin@pfe-soc

☒ Set password

Password ? Confirm Password

Organisation
pfe-soc

Role NIDS SID
 admin

Sync user for
Not bound to a server

PGP key
 Paste the user's PGP key here or try to retrieve it from the CIRCL key server by clicking on "Fetch PGP key" below.

Fetch PGP key

FIGURE 3.11 – Création d'un Utilisateur

Pour maximiser la capacité de détection de notre système, on a activé plusieurs flux de

renseignements sur les menaces dans MISP. Ces flux fournissent des informations actualisées sur les menaces émergentes, permettant ainsi une surveillance proactive.

ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL
1	✓	✓	CIRCL OSINT Feed	misp	CIRCL	network	https://www.circl.lu/doc/misp/feed	
2	✓	✓	The Botvrij.eu Data	misp	Botvrij.eu	network	https://www.botvrij.eu/data/feed	
3	✓	✓	ELLIO: IP Feed (Community version)	freetext	ellio tech	network	https://cdn.ellio.tech/community-f	
4	✓	✓	blockrules of rules.emergingthreats.net	csv	rules.emergingthreats.net	network	https://rules.emergingthreats.net/ips.txt	
5	✓	✓	Tor exit nodes	csv	TOR Node List from dan.me.uk - careful, this feed applies a lock-out after each pull. This is shared with the "Tor ALL nodes" feed.	network	https://www.dan.me.uk/torlist/?ex	
6	✓	✓	Tor ALL nodes	csv	TOR Node List from dan.me.uk - careful, this feed applies a lock-out after each pull. This is shared with the "Tor exit nodes" feed.	network	https://www.dan.me.uk/torlist/	
7	✓	✓	cybercrime-tracker.net - all	freetext	cybercrime-tracker.net	network	https://cybercrime-tracker.net/all	
8	✓	✓	Phishtank online valid phishing	csv	Phishtank	network	https://data.phishtank.com/data/c	
9	✓	✓	ip-block-list - snort.org	freetext	https://snort.org	network	https://snort.org/downloads/ip-bl	
10	✓	✓	diamondfox_panels	freetext	pan-unit42	network	https://raw.githubusercontent.com/unit42/loc/master/diamondfox/d	

FIGURE 3.12 – Activation des Flux de Renseignements sur les Menaces

La figure 3.12 montre la liste des flux de renseignements activés dans MISP. Les flux incluent diverses sources telles que CIRCL OSINT Feed, Botvrij.eu Data, et autres. Chaque flux est configuré pour fournir des informations spécifiques sur les menaces, contribuant ainsi à renforcer la sécurité globale du système.

3.2.3.4 Installation de TheHive

TheHive est une plateforme de gestion des incidents de sécurité. Son intégration avec MISP et Cortex permet une réponse plus rapide et efficace aux incidents, renforçant ainsi la capacité de notre système à détecter et réagir aux menaces.

Pour installer TheHive, on a utilisé la commande `wget` pour télécharger le script d'installation, que l'on a ensuite exécuté pour configurer TheHive. Cette commande permet de récupérer le script d'installation depuis le site de StrangeBee et de l'exécuter pour installer TheHive sur notre système. Une fois l'installation terminée, on a pu accéder à TheHive via l'URL fournie et commencer à configurer l'application.^[21]

Après l'installation, on a créé une organisation pour structurer la gestion des utilisateurs et des incidents dans TheHive.

La figure 3.13 illustre le formulaire de création d'une organisation dans TheHive. On a défini le nom "pfe-soc", ajouté une description, et spécifié les règles de partage des tâches et des observables. Cette organisation servira de base pour la gestion des incidents et la collaboration au sein de notre équipe SOC.

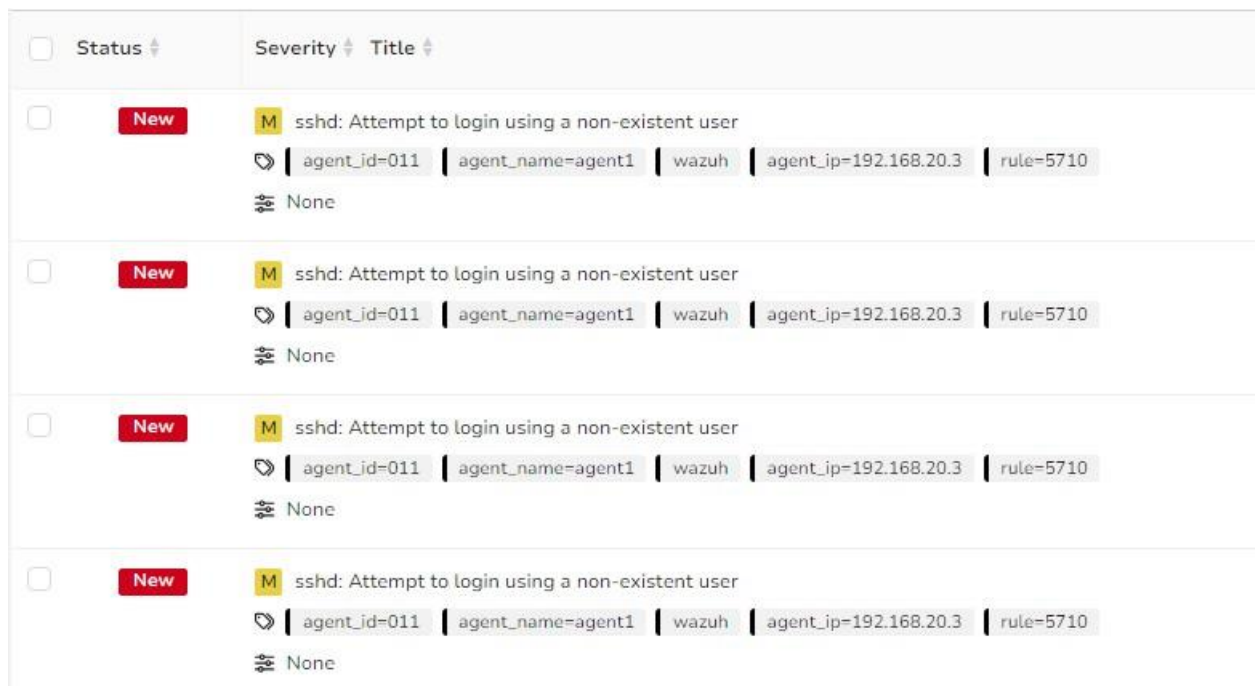
FIGURE 3.13 – Création d'une Organisation

Ensuite, on a créé un utilisateur administrateur pour gérer les opérations et la configuration dans MISP. La figure 3.14 montre le formulaire de création d'un utilisateur dans MISP. On a spécifié l'adresse e-mail, le mot de passe, l'organisation associée, et le rôle de l'utilisateur (admin). Cet utilisateur administrateur aura les droits nécessaires pour configurer et gérer les divers aspects de MISP.

FIGURE 3.14 – Création d'un Utilisateur Activer les flux de renseignements sur les menaces

3.2.3.5 Intégration de MISP avec Wazuh

Pour intégrer MISP avec Wazuh, on a utilisé l'API de MISP afin d'interagir avec les événements et d'enrichir les alertes générées par Wazuh. Un script personnalisé a été téléchargé et installé pour faciliter cette intégration. Après avoir configuré l'intégration entre MISP et Wazuh, les résultats sont visualisables dans l'interface de TheHive. Les alertes générées par Wazuh sont enrichies avec des informations provenant de MISP, ce qui permet une gestion des incidents plus efficace. La figure 3.15 montre les alertes dans l'interface de TheHive, démontrant comment les alertes de Wazuh sont enrichies avec les données de MISP pour une réponse aux incidents plus complète. Chaque alerte contient des détails supplémentaires provenant de MISP, facilitant ainsi l'analyse et la résolution des incidents de sécurité.



☐	Status	Severity	Title
☐	New	M	sshd: Attempt to login using a non-existent user
			agent_id=011 agent_name=agent1 wazuh agent_ip=192.168.20.3 rule=5710
			None
☐	New	M	sshd: Attempt to login using a non-existent user
			agent_id=011 agent_name=agent1 wazuh agent_ip=192.168.20.3 rule=5710
			None
☐	New	M	sshd: Attempt to login using a non-existent user
			agent_id=011 agent_name=agent1 wazuh agent_ip=192.168.20.3 rule=5710
			None
☐	New	M	sshd: Attempt to login using a non-existent user
			agent_id=011 agent_name=agent1 wazuh agent_ip=192.168.20.3 rule=5710
			None

FIGURE 3.15 – Résultat de l'Intégration

3.2.3.6 Installation de cortex

Cortex est utilisé pour l'analyse des incidents de sécurité. L'intégration avec TheHive permet d'automatiser les réponses et les analyses, améliorant ainsi la capacité de notre système à détecter et réagir aux menaces de manière proactive et efficace.

Pour installer Cortex, on a utilisé la commande `wget` pour télécharger le script d'installation, puis on a exécuté ce script pour configurer Cortex. Cette commande permet de récupérer le script d'installation depuis le site de StrangeBee et de l'exécuter pour installer Cortex sur le système. Le script d'installation configure Cortex avec les paramètres nécessaires pour qu'il fonctionne correctement.^[22]

La figure 3.16 montre le formulaire de création d'une organisation dans Cortex, où nous avons défini le nom "XDR" et ajouté une description. Cette organisation servira de base pour

la gestion des analyses et la collaboration au sein de notre équipe SOC. La configuration de l'organisation est essentielle pour structurer et segmenter les différents rôles et responsabilités dans Cortex.

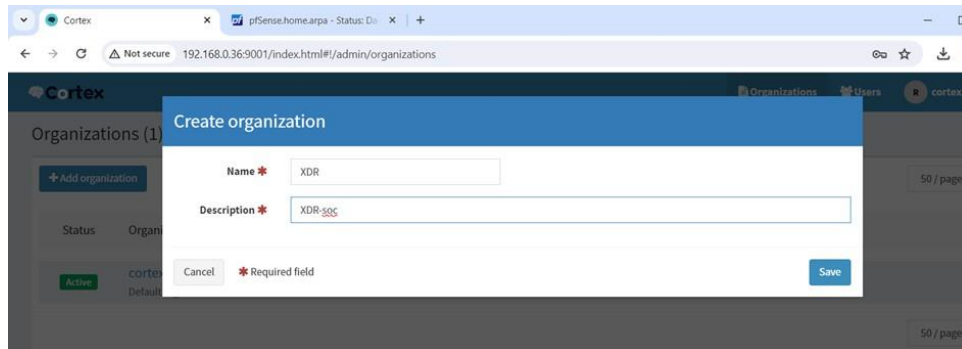


FIGURE 3.16 – Création d'une Organisation

Ensuite, on a créé un utilisateur administrateur pour gérer les opérations dans Cortex. La figure 3.17 montre le formulaire de création d'un utilisateur dans Cortex. Nous avons spécifié l'adresse e-mail "rabe@pfe.soc", le nom "rabe", et avons assigné les rôles nécessaires pour gérer et analyser les incidents de sécurité. L'utilisateur créé a des rôles étendus, notamment la lecture, l'analyse et l'administration de l'organisation, ce qui est crucial pour la gestion des incidents.

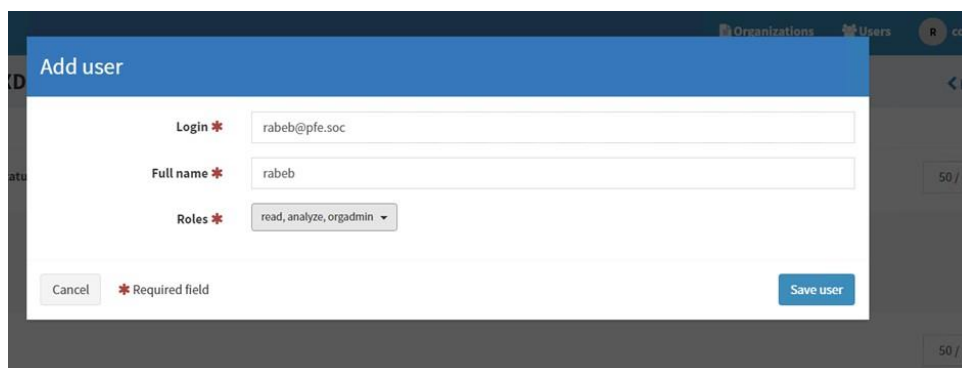


FIGURE 3.17 – Création d'un Utilisateur

3.2.3.7 Intégration de VirusTotal avec Cortex

Pour améliorer nos capacités d'analyse, nous avons intégré VirusTotal avec Cortex. Cette intégration permet d'utiliser les services de VirusTotal pour analyser les fichiers et les URL suspects, enrichissant ainsi nos capacités d'investigation.

FIGURE 3.18 – Intégration de VirusTotal

3.2.3.8 Intégration de TheHive avec Cortex et MISP

Pour compléter notre architecture, on a intégré TheHive avec MISP et Cortex en utilisant une clé API. Cette intégration permet à TheHive d'envoyer des demandes d'analyse à Cortex et de recevoir les résultats, tout en utilisant MISP pour enrichir les informations sur les menaces. Cela automatise le flux de travail des incidents et améliore l'efficacité de notre SOC. L'intégration entre TheHive, MISP et Cortex confirme que les trois plateformes sont connectées et fonctionnent ensemble de manière transparente. Cette intégration est cruciale pour automatiser le processus d'analyse et de réponse aux incidents, améliorant ainsi l'efficacité de notre SOC.

FIGURE 3.19 – Intégration de TheHive avec MISP et Cortex

3.2.3.9 Installation des agents

Les agents Wazuh, installés sur les endpoints, envoient des logs et des alertes au serveur central. Cela permet de surveiller les activités suspectes sur chaque machine, assurant ainsi une sécurité continue et proactive.

Après l'installation de l'agent Wazuh, il est nécessaire de recharger le démon système, d'activer le service Wazuh Agent pour qu'il démarre automatiquement, de lancer le service et de vérifier son statut pour s'assurer de son bon fonctionnement. L'état "active (running)"

confirme que l'agent Wazuh est opérationnel.

```

rabebjerbi031@agent1:~$ sudo systemctl daemon-reload
rabebjerbi031@agent1:~$ sudo systemctl enable wazuh-agent
rabebjerbi031@agent1:~$ sudo systemctl start wazuh-agent
rabebjerbi031@agent1:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/lib/systemd/system/wazuh-agent.service; enabled; vendor preset: enabled)
   Active: active (running) since Wed 2024-05-22 11:33:24 UTC; 17s ago

```

FIGURE 3.20 – Statut de l'Agent Wazuh

Les mêmes étapes s'appliquent pour la machine Windows. Les détails de l'installation sont disponibles en annexe.

3.2.3.10 Intégration de Suricata avec Wazuh

Suricata, en tant que système de détection d'intrusion réseau (IDS), surveille le trafic réseau et envoie les journaux de sécurité au serveur Wazuh pour une analyse plus approfondie. Cette section détaille les étapes d'installation et d'intégration de Suricata avec Wazuh.

Pour configurer l'agent Wazuh sur une machine exécutant Suricata, on a téléchargé et installé l'agent Wazuh en spécifiant le gestionnaire Wazuh et le nom de l'agent. Ensuite, on a rechargé le démon système, activé le service Wazuh Agent pour qu'il démarre automatiquement, démarré le service et vérifié son statut pour s'assurer de son bon fonctionnement. L'état "active (running)" confirme que l'agent Wazuh est opérationnel.

```

rabebjerbi031@suricata:~$ sudo systemctl daemon-reload
rabebjerbi031@suricata:~$ sudo systemctl enable wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service → /lib/systemd/system/wazuh-agent.service.
rabebjerbi031@suricata:~$ sudo systemctl start wazuh-agent
rabebjerbi031@suricata:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/lib/systemd/system/wazuh-agent.service; enabled; vendor preset: enabled)
   Active: active (running) since Tue 2024-05-07 20:42:09 UTC; 24s ago
   Process: 2421 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, sta>

```

FIGURE 3.21 – Activation et Démarrage de l'Agent Wazuh

3.2.3.11 Intégration de suricata avec wazuh

Pour installer Suricata sur l'endpoint Ubuntu, on a d'abord ajouté le dépôt stable de Suricata à la liste des sources de paquets, puis installé Suricata et ses dépendances. Après l'installation, Suricata a été configuré en modifiant le fichier `suricata.yaml` pour définir les réseaux internes et externes ainsi que les chemins des règles. Le fichier de configuration spécifie les paramètres essentiels de Suricata : la variable `HOME_NET` définit l'adresse IP du réseau interne (`<UBUNTU_IP>`), tandis que `EXTERNAL_NET` est configuré sur "any" pour inclure tout le trafic externe. Le chemin par défaut des règles est défini par `default-rule-path`, pointant vers `/etc/suricata/rules`, et tous les fichiers de règles se terminant par `.rules` sont inclus via `rule-files`. Les statistiques sont désactivées avec `stats : enabled : no`. Enfin, `af-packet` configure Suricata pour capturer le trafic réseau en haute vitesse sur l'interface `ens4`, permettant à Suricata de

fonctionner en mode IPS sur l'interface configurée.

Pour permettre à l'agent Wazuh de lire les fichiers de journaux générés par Suricata, on a ajouté la configuration appropriée dans le fichier de configuration de l'agent Wazuh. Cette configuration indique à l'agent Wazuh où trouver les journaux de Suricata, permettant ainsi à Wazuh d'analyser ces journaux et de générer des alertes basées sur ces données.

```
<localfile>
  <log_format>json</log_format>
  <location>/var/log/suricata/eve.json</location>
</localfile>

</ossec_config>
```

FIGURE 3.22 – Configuration de l'Agent Wazuh

Ensuite, on a ajouté la même configuration dans le fichier de configuration du manager Wazuh et redémarré le service pour appliquer les changements. Ces étapes permettent de modifier la configuration du manager Wazuh et de redémarrer le service pour appliquer les nouveaux paramètres. L'état "active (running)" confirme que le manager Wazuh est opérationnel et prêt à recevoir les journaux de Suricata pour analyse.

```
rabebjerbi031@master:~$ sudo nano /var/ossec/etc/ossec.conf
rabebjerbi031@master:~$ sudo systemctl restart wazuh-manager.service
rabebjerbi031@master:~$ sudo systemctl status wazuh-manager.service
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enable
   Active: active (running) since Tue 2024-05-07 20:59:34 UTC; 16s ago
```

FIGURE 3.23 – Status de wazuh manager

3.2.3.12 Intégration de pfsense avec wazuh

pfSense, en tant que pare-feu, protège notre réseau XDR. L'intégration de pfSense avec Wazuh permet de centraliser les logs de sécurité pour une analyse approfondie, offrant ainsi une meilleure visibilité et une gestion centralisée des événements de sécurité.

Pour installer l'agent Wazuh sur pfSense, on a téléchargé et installé l'agent Wazuh depuis les dépôts de pfSense, préparant ainsi l'agent pour la collecte et la transmission des logs de sécurité. Après l'installation, on a activé et démarré le service Wazuh Agent pour s'assurer qu'il est opérationnel et prêt à fonctionner.

```
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: /usr/local/etc/rc.d/wazuh-agent enable
wazuh agent enabled in /etc/rc.conf
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: /usr/local/etc/rc.d/wazuh-agent start
Starting Wazuh Agent: 2024/05/14 19:54:02 wazuh-syscheckd: WARNING: The check_unixaudit option
is deprecated in favor of the SCA module.
success
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: █
```

FIGURE 3.24 – Démarrage de l'Agent Wazuh sur pfSense

3.3 Conclusion

Dans ce chapitre, on a détaillé la configuration des composants clés, des machines virtuelles, ainsi que des systèmes d'exploitation et des logiciels nécessaires. Chaque composant a été intégré de manière à fonctionner harmonieusement, garantissant une sécurité optimale et une réponse rapide aux incidents. Le prochain chapitre se concentrera sur les tests de notre architecture XDR, en décrivant les différents scénarios d'attaque que nous avons simulés et les résultats obtenus.

Chapitre 4

Test

4.1 Introduction

Dans ce chapitre, on se concentrera sur les tests de notre architecture XDR. On décrira les différents scénarios d'attaque simulés, comment ces attaques ont été émulées sur les machines Ubuntu et Windows, et comment Wazuh a détecté et répondu à ces incidents. On analysera également les résultats des tests pour évaluer l'efficacité de notre solution XDR.

4.2 Blocage d'un Acteur Malveillant

4.2.1 Description de l'attaque

Cette attaque consiste à détecter et bloquer les tentatives de connexion provenant d'un acteur malveillant non connu. Les attaquants malveillants utilisent souvent des adresses IP aléatoires pour lancer des attaques contre des systèmes cibles. Identifier et bloquer ces adresses IP est une mesure proactive de sécurité pour prévenir les accès non autorisés et les tentatives de compromission.

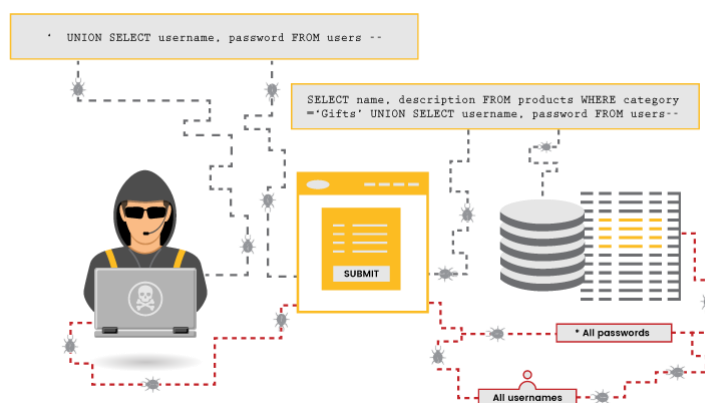


FIGURE 4.1 – Blocage d'un Acteur Malveillant
[23]

4.2.2 Attaque Simulée

Pour simuler cette attaque, on a utilisé une machine attaquante Kali pour envoyer des requêtes HTTP à une machine cible. On a utilisé l'adresse IP d'un acteur non connu pour générer des logs et observer la réaction de notre système de détection. La commande `curl http://192.168.20.3` a été utilisée pour envoyer une requête HTTP à partir de la machine attaquante avec l'IP non connue.

```
rabebjerbi031@kali:~$ curl http://192.168.20.3
<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <!--
    Modified from the Debian original for Ubuntu
    Last updated: 2016-11-16
    See: https://launchpad.net/bugs/1288690
  -->
  <head>
```

FIGURE 4.2 – Simulation de l'attaque

Après la simulation de l'attaque, les alertes générées par Wazuh pour les tentatives de connexion provenant de l'IP non connue ont été analysées pour comprendre la nature de l'attaque et prendre les mesures appropriées.

May 23, 2024 @ 11:15:55.207 agent1 sshd: Attempt to login using a non-existent user

Expanded document

Table	JSON
GeoLocation.city_name	Daejeon
GeoLocation.country_name	South Korea
GeoLocation.location	{ "lon": 127.4197, "lat": 36.3214 }
GeoLocation.region_name	Daejeon
_index	wazuh-alerts-4.x-2024.05.23
agent.id	011
agent.ip	192.168.20.3
agent.name	agent1
cluster.name	wazuh

FIGURE 4.3 – Alerte Wazuh

Une alerte générée par Wazuh indiquait une tentative de connexion depuis une adresse IP suspecte et non connue. Les détails supplémentaires de l'alerte incluaient des informations de géolocalisation et des indicateurs de compromission (IoCs).

t rule.groups	syslog, sshd, authentication_failed, invalid_login
t rule.hipaa	164.312.b
t rule.id	5710
# rule.level	5
rule.mail	false
t rule.mitre.id	T1110.001, T1021.004
t rule.mitre.tactic	Credential Access, Lateral Movement
t rule.mitre.technique	Password Guessing, SSH
t rule.nist_800_53	AU.14, AC.7, AU.6

FIGURE 4.4 – Détails de l'alerte Wazuh

Les alertes Wazuh intégrées dans The Hive ont permis une gestion centralisée et une analyse approfondie des incidents de sécurité, facilitant ainsi la gestion des incidents et la réponse aux attaques

sshd: Attempt to login using a non-existent user

id ~361451760
Created by Rabeab
Created at 23/05/2024 10:22

SEVERITY:MEDIUM
TLP:AMBER PAP:AMBER

Assignee Assign to me
Unassigned

Source
wazuh

Reference
03a18d

Type
wazuh_alert

Occurred date
23/05/2024 10:22

Status
New

General Observables (3) TTPs (0) Attachments Similar Cases Similar Alerts Resolved

Tags
agent_id=011 agent_name=agent1 wazuh agent_ip=192.168.20.3 rule=5710

Description

Timestamp

key	val
timestamp	2024-05-23T10:22:39.624+0000

Rule

key	val
rule.level	5
rule.description	sshd: Attempt to login using a non-existent user
rule.id	5710
rule.mitre.id	['T1110.001', 'T1021.004']
rule.mitre.tactic	['Credential Access', 'Lateral Movement']

FIGURE 4.5 – Alerte dans The Hive

Pour confirmer la nature malveillante de l'IP source, on a utilisé VirusTotal pour analyser l'IP et vérifier les rapports de sécurité. Les résultats ont montré une alerte générée par Wazuh indiquant une tentative de connexion depuis une adresse IP connue pour être malveillante (220.78.28.115). Cette alerte était associée à plusieurs indicateurs de compromission (IoCs) et techniques MITRE.^[24]

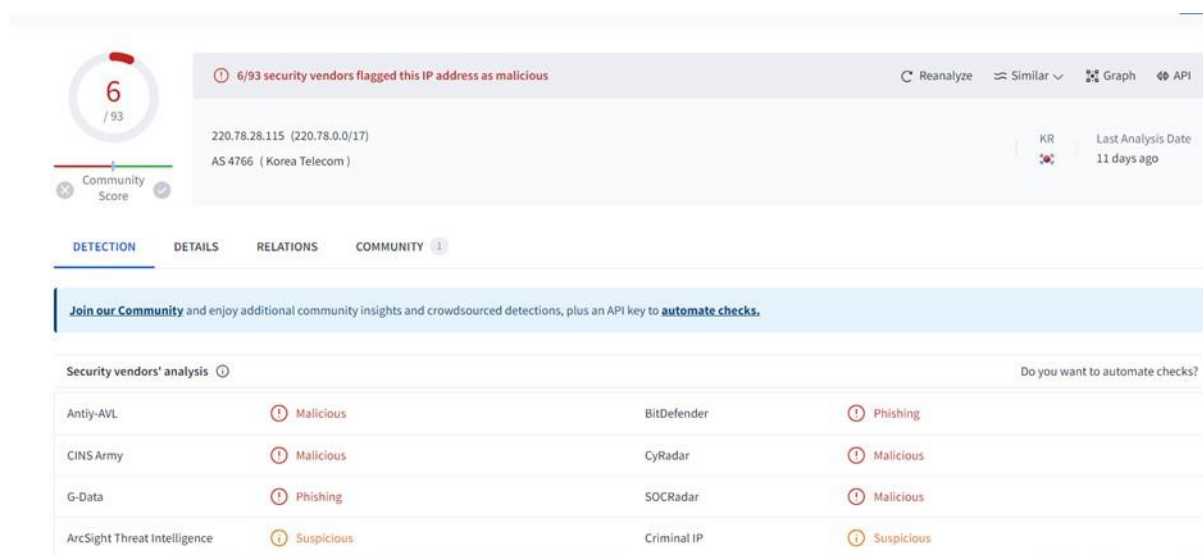


FIGURE 4.6 – Alerte VirusTotal

MITRE ID T1110.001 : Cette technique, connue sous le nom de "Brute Force : Password Guessing", implique que l'attaquant essaie systématiquement de deviner les mots de passe pour obtenir un accès non autorisé. Les services souvent ciblés comprennent SSH, Telnet, FTP, etc. Cette technique est utilisée par les attaquants pour essayer d'accéder à des comptes protégés par des mots de passe faibles ou communs.^[7]

MITRE ID T1021.004 : Cette technique, "Remote Services : SSH", implique l'utilisation de comptes valides pour se connecter à des machines distantes en utilisant SSH. L'attaquant peut ensuite exécuter des actions en tant qu'utilisateur connecté. Cette méthode permet aux attaquants de se déplacer latéralement dans le réseau et d'exécuter des commandes malveillantes à distance. En utilisant VirusTotal, on a confirmé que l'adresse IP attaquante (220.78.28.115) a été signalée comme malveillante par plusieurs services de sécurité, avec des indicateurs de phishing et d'activités suspectes. Cette vérification supplémentaire renforce la crédibilité de l'alerte et confirme que l'adresse IP est associée à des activités malveillantes connues. Pour contrer ces attaques, on a configuré une réponse active dans Wazuh pour bloquer les adresses IP malveillantes en ajoutant les commandes de réponse active dans le fichier de configuration ossec.conf.^[25]

Après cette configuration, on a resimulé l'attaque. Les alertes montrent que Wazuh a détecté une activité malveillante provenant d'une adresse IP spécifique et a automatiquement appliqué la commande de blocage définie dans la réponse active. Les détails de l'alerte générée incluent des informations telles que le niveau de la règle, l'ID de la règle, et les groupes auxquels la règle appartient.^[26]

```

<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5710</rules_id>
  <timeout></timeout>
</active-response>

```

FIGURE 4.7 – Configuration de la réponse active dans Wazuh

Grâce à la configuration de la réponse active de Wazuh, l'attaque a été détectée et l'adresse IP malveillante a été automatiquement bloquée. Les alertes générées ont montré que Wazuh a efficacement identifié les tentatives de connexion suspectes, appliqué les règles de sécurité configurées et empêché toute compromission potentielle en bloquant immédiatement l'adresse IP de l'attaquant. Cette réponse rapide et automatique a permis de sécuriser le système contre les accès non autorisés.

4.3 Injection SQL

4.3.1 Description de l'attaque

Une attaque par injection SQL permet à un attaquant d'exécuter des requêtes SQL malveillantes sur une base de données en exploitant des vulnérabilités dans les applications web. Cela peut permettre d'accéder, de manipuler ou de supprimer des données de manière non autorisée.

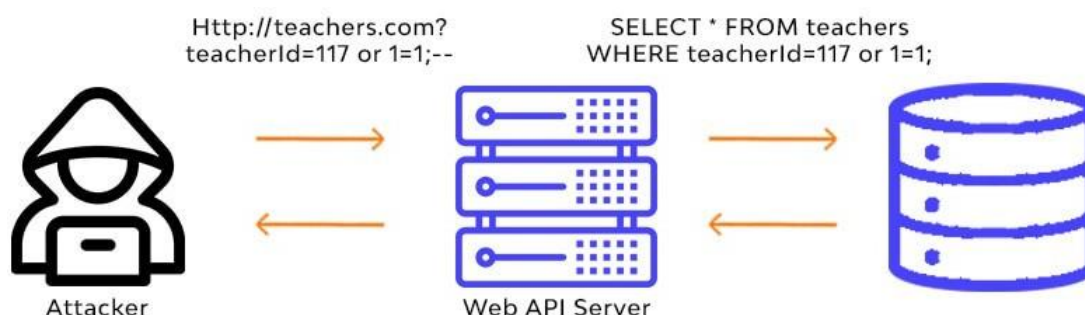


FIGURE 4.8 – injection SQL

[23]

4.3.2 Attaque Simulée

Pour simuler cette attaque, une requête malveillante a été envoyée à une application web sur une machine windows. On a répété le test sur une machine Windows pour vérifier la détection cohérente de l'injection SQL sur différentes plateformes.

```

rabeberbi031@kali:~$ curl -XGET "http://192.168.20.3/users/?id=SELECT**FROM+users"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.41 (Ubuntu) Server at 192.168.20.3 Port 80</address>
</body></html>

```

FIGURE 4.9 – Simulation d'attaque

Les alertes générées par Wazuh ont permis de détecter cette tentative d'injection SQL.

May 23, 2024 @ 15:37:48.305 agent1 SQL injection attempt.

Expanded document [View surrounding d](#)

Table	JSON
† _index	wazuh-alerts-4.x-2024.05.23
† agent.id	011
† agent.ip	192.168.20.3
† agent.name	agent1
† cluster.name	wazuh
† cluster.node	master-node
† data.id	404
† data.protocol	GET
† data.srcip	192.168.0.8
† data.url	/users/?id=SELECT**FROM+users
† decoder.name	web-accesslog
† full_log	192.168.0.8 - - [23/May/2024:14:37:47 +0000] "GET /users/?id=SELECT**FROM+users HTTP/1.1" 404 435 "-" "curl/8.5.0"
† id	1716475068.2438984
† input.type	log
† location	/var/log/apache2/access.log

FIGURE 4.10 – Tentative d'injection SQL

La figure 4.10 fournit une vue détaillée de l'alerte sur la machine Windows, confirmant la cohérence de la détection.

SQL injection attempt.

Id -378921184
Created by Rabeb
Created at 23/05/2024 15:00

SEVERITY: MEDIUM
TLP: AMBER
Assignee: Assign to me
Unassigned

Source: wazuh
Reference: f65dc7
Type: wazuh_alert
Occurred date: 23/05/2024 15:00
Status: New

rule.mail: False
rule.groups: ['web', 'accesslog', 'attack', 'sql_injection']
rule.pci_dss: ['6.5', '11.4', '6.5.1']
rule.gdpr: ['IV_35.7.d']
rule.nist_800_53: ['5A.11', '5I.4']
rule.tsc: ['CC6.6', 'CC7.1', 'CC8.1', 'CC6.1', 'CC6.8', 'CC7.2', 'CC7.3']

Agent

key	val
agent.id	011
agent.name	agent1
agent.ip	192.168.20.3

Manager

key	val
manager.name	master

Id

key	val
id	1716476422.2484779

FIGURE 4.11 – Alerte dans The Hive

Les résultats montrent que Wazuh a correctement détecté les tentatives d'injection SQL sur les machines Ubuntu et Windows. Les alertes sont associées à plusieurs techniques MITRE : T1190 : "Exploit Public-Facing Application" - L'attaque implique l'exploitation d'une application accessible au public pour obtenir un accès initial. T1190.001 : "SQL Injection" - La méthode spécifique utilisée pour l'attaque est l'injection SQL. Les alertes Wazuh contiennent également des informations détaillées sur les groupes de règles, les niveaux de gravité et les indicateurs de compromission.

4.3.2.1 Active Response

Ensuite, on a configuré une réponse active dans Wazuh pour bloquer les adresses IP malveillantes identifiées comme tentant des injections SQL. La configuration inclut l'utilisation de la commande firewall-drop pour bloquer localement les adresses IP identifiées par les règles spécifiées, avec un délai d'expiration de 60 secondes.

Time	agent.name	rule.description
> May 23, 2024 @ 16:12:23.533	agent1	Host Blocked by firewall-drop Active Response
> May 23, 2024 @ 16:12:23.448	agent1	SQL injection attempt.

FIGURE 4.12 – réponse active

On a simulé une tentative d'injection SQL depuis une machine attaquante en envoyant une requête malveillante au serveur web. Wazuh détecte la tentative d'injection SQL et génère une

alerte, comme illustré ci-dessous.

```

rabebjerbi031@kali:~$ curl -XGET "http://192.168.20.3/users/?id=SELECT**FROM+users"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.41 (Ubuntu) Server at 192.168.20.3 Port 80</address>
</body></html>

```

FIGURE 4.13 – Alertes Wazuh

Cette alerte indique que l'hôte attaquant a été bloqué par la réponse active de Wazuh, empêchant ainsi toute nouvelle tentative d'injection SQL. Enfin, nous avons vérifié que l'adresse IP de la machine attaquante (Kali Linux) a été bloquée en tentant de renvoyer la même requête malveillante.

```

rabebjerbi031@kali:~$ curl -XGET "http://192.168.20.3/users/?id=SELECT**FROM+users"
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.41 (Ubuntu) Server at 192.168.20.3 Port 80</address>
</body></html>
rabebjerbi031@kali:~$ curl -XGET "http://192.168.20.3/users/?id=SELECT**FROM+users"
^C
rabebjerbi031@kali:~$ ping 192.168.20.3
PING 192.168.20.3 (192.168.20.3) 56(84) bytes of data.
64 bytes from 192.168.20.3: icmp_seq=25 ttl=64 time=0.559 ms
64 bytes from 192.168.20.3: icmp_seq=26 ttl=64 time=0.228 ms
64 bytes from 192.168.20.3: icmp_seq=27 ttl=64 time=0.203 ms
64 bytes from 192.168.20.3: icmp_seq=28 ttl=64 time=0.207 ms
^C
--- 192.168.20.3 ping statistics ---
28 packets transmitted, 4 received, 85.7143% packet loss, time 27644ms
rtt min/avg/max/mdev = 0.203/0.299/0.559/0.150 ms
rabebjerbi031@kali:~$

```

FIGURE 4.14 – Simulation d'attaque

4.4 Attaque Shellshock

4.4.1 Description de l'attaque

Shellshock est une vulnérabilité critique dans Bash qui permet à un attaquant d'exécuter des commandes arbitraires sur un système vulnérable en exploitant des failles dans les variables d'environnement

4.4.1.1 Émulation des Attaques

La détection par Wazuh d'une tentative d'attaque Shellshock montre comment cette attaque exploite une vulnérabilité dans le shell Bash pour exécuter des commandes arbitraires sur le serveur.

```
(Run: "touch ~/.hushlogin" to hide this message)
rabeberbi031@kali:~$ curl -XGET "http://192.168.0.56/users/?id=SELECT**FROM+users";
```

FIGURE 4.15 – Simulation d'attaque

L'alerte générée par Wazuh en réponse à cette tentative capture les détails de l'attaque, y compris l'URL de la requête et les informations sur l'agent. Cela montre la précision de Wazuh dans l'identification des vecteurs d'attaque et la collecte des informations nécessaires pour une analyse approfondie.



Expanded document	
Table	JSON
Index	wazuh-alerts-4.x-2024.05.25
agent.id	011
agent.ip	192.168.20.3
agent.name	agent1
cluster.name	wazuh
cluster.node	master-node
data.id	200
data.protocol	GET
data.srcip	192.168.0.8
data.url	/
decoder.name	web-accesslog
full_log	192.168.0.8 - - [25/May/2024:15:53:19 +0000] "GET / HTTP/1.1" 200 11173 "-" {} { :: }; /bin/cat /etc/passwd"
id	1716652401.32993898

FIGURE 4.16 – Alertes Wazuh

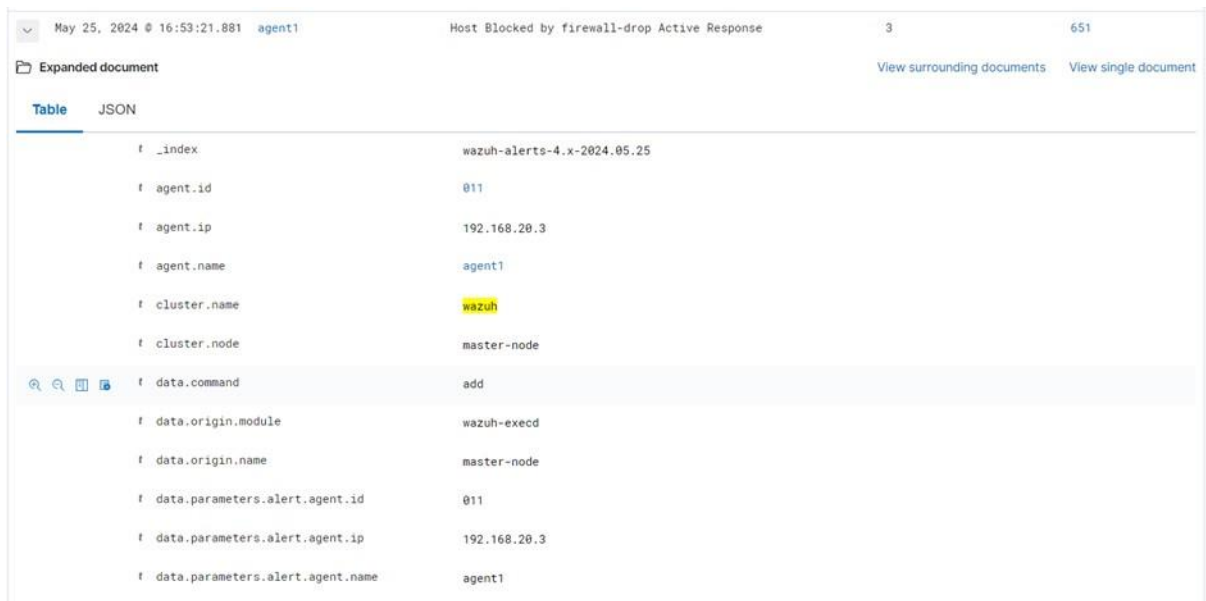
La configuration des réponses actives est essentielle dans ce cas. Cette configuration permet de bloquer automatiquement les adresses IP à l'origine des attaques Shellshock. La commande `firewall-drop-Shellshock-attack` est spécifiquement configurée pour la règle 31168, avec un délai de 180 secondes, ce qui signifie que l'adresse IP de l'attaquant sera bloquée temporairement pour empêcher d'autres tentatives.

```
<active-response>
  <command>firewall-drop-Shellshock-attack</command>
  <location>local</location>
  <rules_id>31168</rules_id>
  <timeout>180</timeout>
</active-response>
```

FIGURE 4.17 – Réponse active

Wazuh met en œuvre cette réponse active de manière efficace. Après la détection de l'attaque Shellshock, l'adresse IP de l'attaquant est automatiquement bloquée. Cette mesure proac-

tive empêche les attaquants d'exploiter davantage la vulnérabilité et protège le système contre l'exécution de commandes arbitraires.



The screenshot shows a Wazuh alert interface. At the top, it displays the date and time 'May 25, 2024 @ 16:53:21.881' and the agent name 'agent1'. The alert message is 'Host Blocked by firewall-drop Active Response'. There are two status indicators: '3' and '651'. Below the message, there are links for 'Expanded document', 'View surrounding documents', and 'View single document'. The main content is a table with two tabs: 'Table' (selected) and 'JSON'. The table lists the following fields and values:

Field	Value
_index	wazuh-alerts-4.x-2024.05.25
agent.id	011
agent.ip	192.168.20.3
agent.name	agent1
cluster.name	wazuh
cluster.node	master-node
data.command	add
data.origin.module	wazuh-execd
data.origin.name	master-node
data.parameters.alert.agent.id	011
data.parameters.alert.agent.ip	192.168.20.3
data.parameters.alert.agent.name	agent1

FIGURE 4.18 – Alerte Wazuh

Grâce à cette approche, le système est efficacement protégé contre les tentatives d'exploitation de la vulnérabilité Shellshock. Cela démontre l'efficacité de Wazuh non seulement pour détecter les attaques, mais aussi pour mettre en place des contre-mesures automatiques pour empêcher toute compromission future.

4.5 Scan Nmap

4.5.1 Description de l'attaque

Nmap est un outil de scan de réseau utilisé pour découvrir les hôtes et les services sur un réseau informatique. Les attaquants l'utilisent pour identifier les systèmes vulnérables et planifier des attaques en exploitant ces vulnérabilités.

4.5.2 Émulation des Attaques

Pour simuler un scan de ports avec Nmap, on a exécuté la commande suivante depuis une machine Kali Linux

```

rabebjerbi031@kali:~$ sudo nmap -sS --script=vuln 192.168.20.3
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-05-25 13:34 UTC
Nmap scan report for agent1.europe-central2-a.c.pfeee-421719.internal (192.168.20.3)
Host is up (0.000067s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.

Nmap done: 1 IP address (1 host up) scanned in 31.79 seconds
rabebjerbi031@kali:~$

```

FIGURE 4.19 – Simulation d’attaque

Cette opération tente d’identifier les services actifs et les vulnérabilités sur la machine cible. On a configuré une réponse active dans Wazuh pour bloquer automatiquement les adresses IP des attaquants lorsqu’un scan de ports est détecté. La configuration dans le fichier de règles du manager Wazuh inclut la commande firewall-drop pour bloquer les adresses IP malveillantes.

```

<rule id="100201" level="12">
  <if_sid>86600</if_sid>
  <field name="event_type">^alert$</field>
  <match>ET SCAN Nmap Scripting Engine User-Agent Detected (Nmap Scripting Engine)</match>
  <description>Nmap scripting engine detected. </description>
  <mitre>
    <id>T1595</id>
  </mitre>
</rule>
</group>

```

FIGURE 4.20 – script

La détection du scan de ports par Suricata intégré avec Wazuh montre que l’alerte capturée indique une activité suspecte correspondant à un scan de ports Nmap. Les détails de l’alerte incluent l’adresse IP de l’attaquant, les services ciblés et les types de vulnérabilités détectées.

May 25, 2024 @ 14:22:51.537

Suricata: Alert - ET SCAN Possible Nmap User-Agent Observed

3

86601

Expanded document

View surrounding documents

View single document

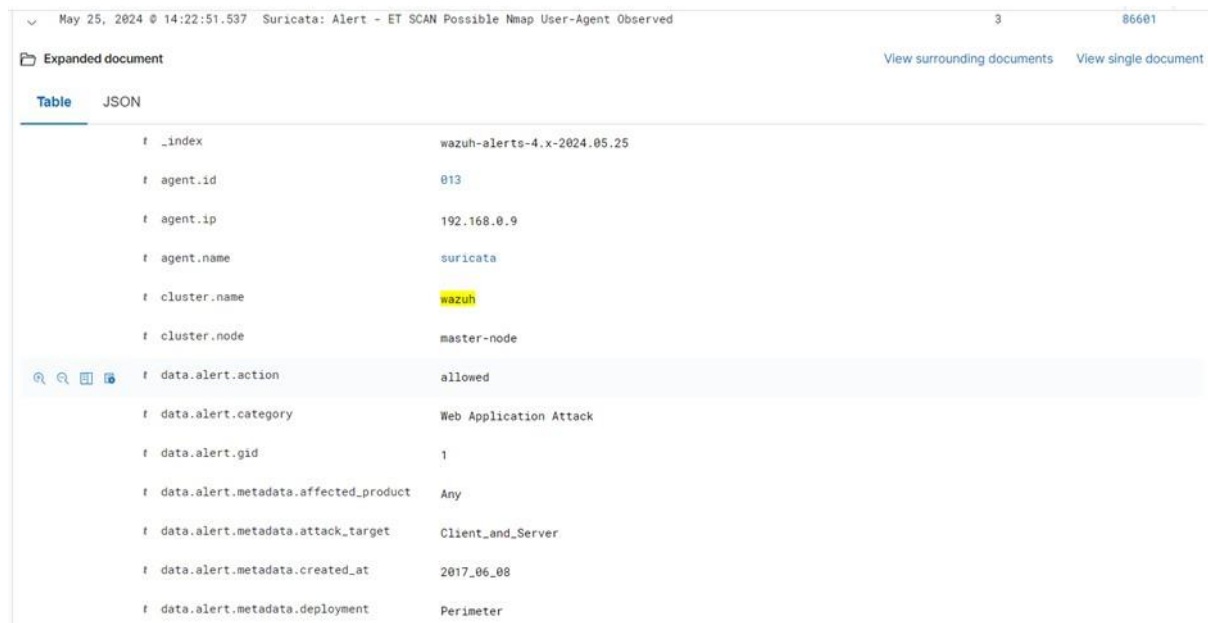
Table

JSON

f _index	wazuh-alerts-4.x-2024.05.25
f agent.id	013
f agent.ip	192.168.0.9
f agent.name	suricata
f cluster.name	wazuh
f cluster.node	master-node
f data.alert.action	allowed
f data.alert.category	Web Application Attack
f data.alert.gid	1
f data.alert.metadata.affected_product	Any
f data.alert.metadata.attack_target	Client_and_Server
f data.alert.metadata.created_at	2017_06_08
f data.alert.metadata.deployment	Perimeter

FIGURE 4.21 – Alertes Wazuh

Les résultats montrent que Wazuh, en collaboration avec Suricata, a pu détecter efficacement les scans de ports effectués par Nmap. Les alertes générées comprennent des informations détaillées sur l'adresse IP de l'attaquant, les services ciblés, et les types de vulnérabilités découvertes. La configuration de la réponse active permet de bloquer immédiatement toute adresse IP suspecte, empêchant ainsi les attaquants de recueillir davantage d'informations sur le réseau cible.



Field	Value
_index	wazuh-alerts-4.x-2024.05.25
agent.id	013
agent.ip	192.168.0.9
agent.name	suricata
cluster.name	wazuh
cluster.node	master-node
data.alert.action	allowed
data.alert.category	Web Application Attack
data.alert.gid	1
data.alert.metadata.affected_product	Any
data.alert.metadata.attack_target	Client_and_Server
data.alert.metadata.created_at	2017_06_08
data.alert.metadata.deployment	Perimeter

FIGURE 4.22 – Réponse active

Grâce à la configuration de Wazuh et de Suricata, nous avons non seulement détecté cette activité malveillante, mais aussi mis en place des mesures pour bloquer les attaquants et protéger notre réseau. Cette approche proactive renforce la sécurité du système en détectant rapidement les tentatives de reconnaissance et en empêchant les attaques potentielles avant qu'elles ne puissent se concrétiser.

4.6 Conclusion

Dans ce chapitre, on a décrit et simulé divers scénarios d'attaque afin de tester l'efficacité de notre architecture XDR. On a expliqué comment ces attaques ont été émulées sur des machines Ubuntu et Windows, et on a interprété les alertes générées par Wazuh. De plus, on a détaillé les réponses actives mises en œuvre pour chaque incident. Le prochain chapitre se concentrera sur l'analyse des résultats de ces tests, l'évaluation des performances de notre solution XDR, ainsi que sur les améliorations possibles.

Conclusion Générale

L'objectif principal de notre projet était de mettre en place un réseau sécurisé pour l'entreprise ATT, en répondant précisément à ses besoins spécifiques. Pour atteindre cet objectif, on a d'abord réalisé une analyse approfondie des exigences de l'entreprise et collecté les informations pertinentes. Ensuite, on a développé une architecture de sécurité robuste intégrant des Centres d'Opérations de Sécurité (SOC) et des solutions de Détection et Réponse Étendues (XDR).

Cette architecture a été conçue pour offrir une surveillance continue et une détection proactive des menaces, en intégrant des données issues de multiples sources—réseaux, endpoints, serveurs, etc... On a configuré et intégré les différentes composantes de cette architecture afin d'assurer une réponse coordonnée et efficace aux incidents de sécurité. De plus, on a effectué des tests de sécurité en simulant diverses attaques pour évaluer les performances de notre solution, garantissant ainsi sa robustesse et sa fiabilité.

En outre, on a mis en place des contre-mesures pour anticiper et corriger d'éventuelles défaillances, renforçant ainsi la résilience de l'infrastructure de sécurité de l'entreprise. Pour les perspectives d'amélioration, on envisage plusieurs axes stratégiques. Premièrement, l'intégration de l'intelligence artificielle et de l'apprentissage automatique permettrait une détection encore plus fine et proactive des menaces, en identifiant des comportements anormaux et des menaces émergentes en temps réel. Deuxièmement, l'automatisation des réponses aux incidents grâce à des solutions avancées de gestion des incidents et l'intégration d'orchestrateurs de sécurité permettrait de coordonner les actions de réponse automatiquement et de réduire significativement les temps de réaction.

Ces améliorations potentielles ouvriraient de nouveaux horizons en termes de performances, de sécurité et de gestion du réseau, assurant ainsi que l'entreprise ATT reste protégée contre un spectre toujours plus large et sophistiqué de cybermenaces.

Webographie

- [1] Paloaltonetworks. <https://www.paloaltonetworks.com/cyberpedia/soc-roles-and-responsibilities>.
- [2] cynet. <https://www.cynet.com/incident-response/what-is-a-soc-10-core-functions-and-6-key-challenges/>.
- [3] Wazuh. <https://documentation.wazuh.com/current/index.html>.
- [4] Microsoft defender xdr. <https://www.microsoft.com/fr-fr/security/business/siem-and-xdr/microsoft-defender-xdr>.
- [5] splunk. https://www.splunk.com/fr_fr.
- [6] Ibm security qradar. <https://www.ibm.com/qradar>.
- [7] Suricata. <https://suricata.io/>.
- [8] Zeek. <https://zeek.org/>.
- [9] Snort. <https://www.snort.org/>.
- [10] Cortex xsoar. <https://xsoar.pan.dev/>.
- [11] Splunk phantom. <https://docs.splunk.com/Documentation/Phantom/4.10.7/User/Intro>.
- [12] Threat intelligence platform. <https://www.misp-project.org/>.
- [13] Recorded future. <https://www.recordedfuture.com/>.
- [14] Threatconnect. <https://threatconnect.com/>.
- [15] pfsense. <https://www.pfsense.org/>.
- [16] Cisco asa. <https://www.cisco.com/c/en/us/products/security/adaptive-security-appliance-asa-software/index.html>.
- [17] Fortinet fortigate. <https://www.fortinet.com/support/support-services/fortiguard-security-subscriptions/industrial-security>.

- [18] Haproxy. <https://www.haproxy.com/fr>.
- [19] Nginx. <https://nginx.org/en/>.
- [20] F5 big-ip. <https://www.f5.com/products/big-ip-services>.
- [21] Thetive. <https://thehive-project.org/>.
- [22] Cortex. <https://thehive-project.org/>.
- [23] Sql injection. <https://www.wallarm.com/what/structured-query-language-injection-sqli-part-1>.
- [24] Virustotal. <https://blog.virustotal.com/2022/11/threat-hunting-with-virustotal.html>.
- [25] Mitre attack-t1021. <https://attack.mitre.org/techniques/T1021/004/>.
- [26] Active-response. <https://documentation.wazuh.com/current/user-manual/capabilities/active-response/index.html>.

Annexe A

Annexes

Annexe A : Création et Configuration des Machines Virtuelles

Cette étape consiste à créer les machines virtuelles qui formeront l'infrastructure de notre solution XDR. En utilisant GCP, nous pouvons rapidement déployer et configurer des instances virtuelles selon nos besoins spécifiques.

1. Accédez à la console Google Cloud Platform et créez un projet.
2. Dans le menu de navigation, sélectionnez "Compute Engine" et cliquez sur "Instances de VM".
3. Cliquez sur "Créer une instance" pour démarrer le processus de création d'une nouvelle machine virtuelle.

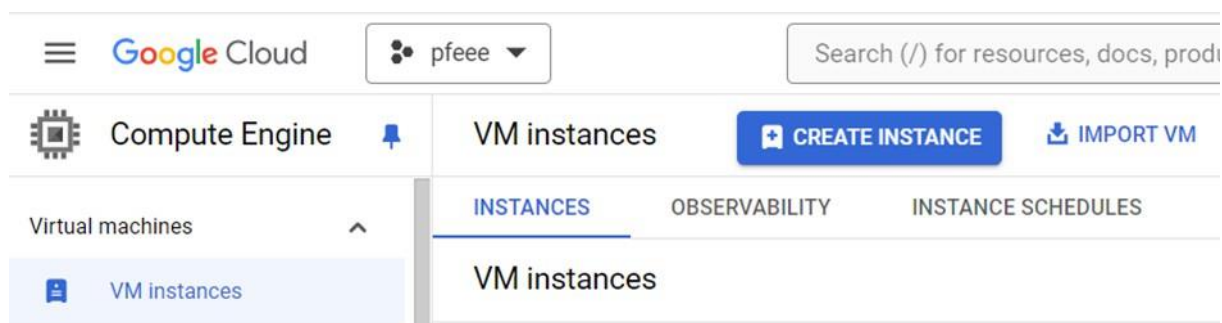
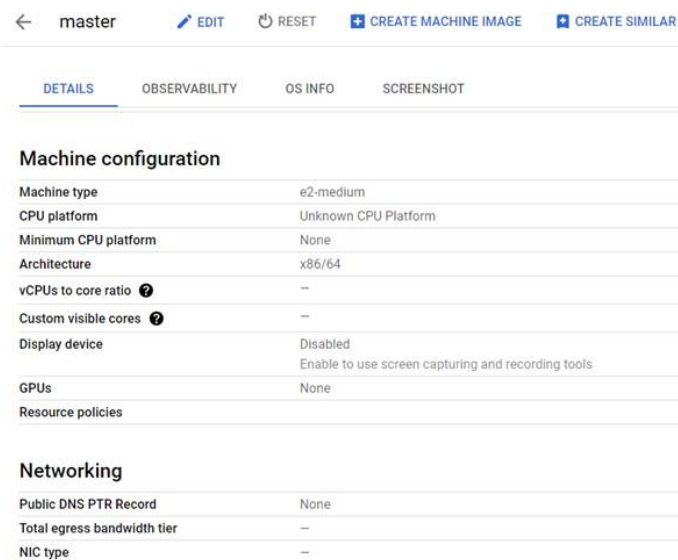


FIGURE A.1 – Création des VMs

Wazuh Manager (Master)

- Configuration Initiale : Sélectionnez le type de machine (2 vCPUs, 4 GB RAM), le système d'exploitation (Ubuntu 20.04 LTS), et configurez le disque persistant (30 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.2 à la VM.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.



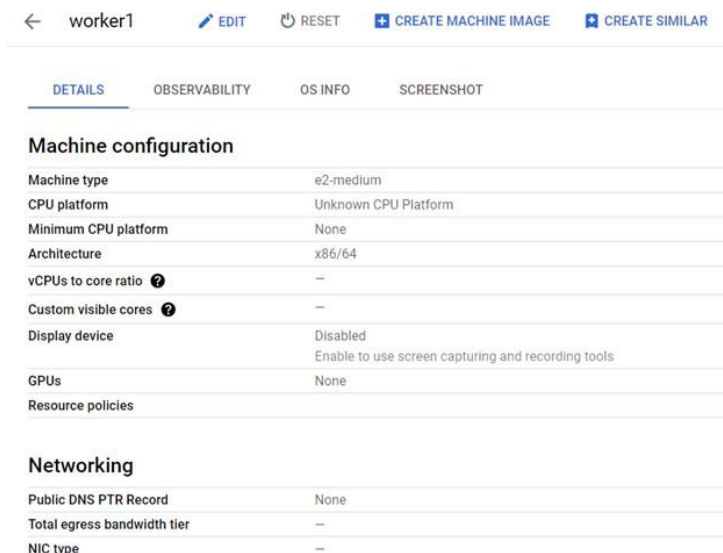
Machine configuration	
Machine type	e2-medium
CPU platform	Unknown CPU Platform
Minimum CPU platform	None
Architecture	x86/64
vCPUs to core ratio ?	—
Custom visible cores ?	—
Display device	Disabled Enable to use screen capturing and recording tools
GPUs	None
Resource policies	

Networking	
Public DNS PTR Record	None
Total egress bandwidth tier	—
NIC type	—

FIGURE A.2 – Vm Wazuh master

Wazuh Workers (Worker 1 et Worker 2)

- Configuration Initiale : Pour chaque worker, sélectionnez le type de machine (2 vCPUs, 4 GB RAM), le système d'exploitation (Ubuntu 20.04 LTS), et configurez le disque persistant (30 GB).
- Réseau : Attribuez les adresses IP 192.168.0.3 et 192.168.0.31 respectivement.
- Déploiement : Cliquez sur "Créer" pour chaque worker.



Machine configuration	
Machine type	e2-medium
CPU platform	Unknown CPU Platform
Minimum CPU platform	None
Architecture	x86/64
vCPUs to core ratio ?	—
Custom visible cores ?	—
Display device	Disabled Enable to use screen capturing and recording tools
GPUs	None
Resource policies	

Networking	
Public DNS PTR Record	None
Total egress bandwidth tier	—
NIC type	—

FIGURE A.3 – Vm Worker 1

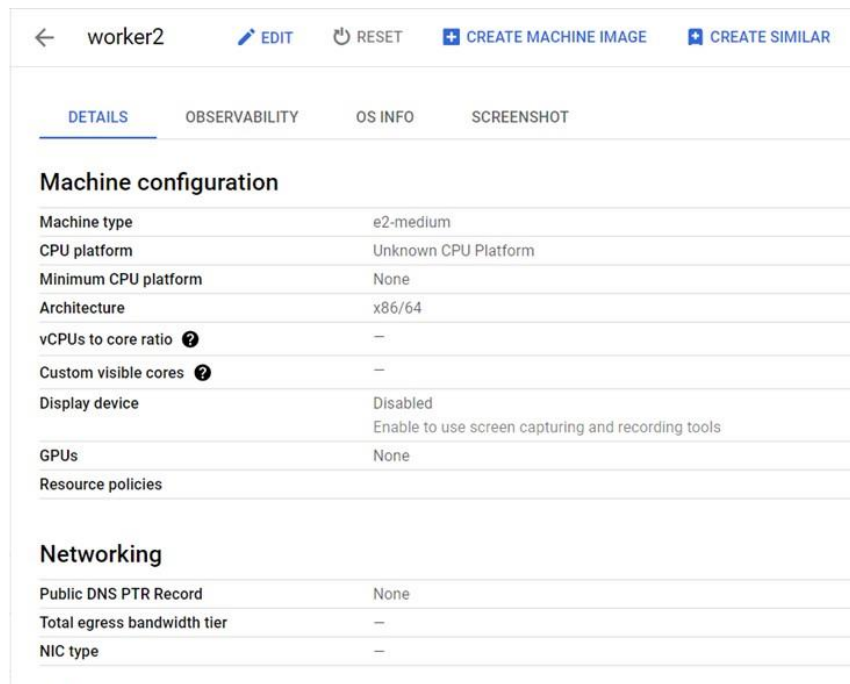


FIGURE A.4 – Vm worker 2

Load balancer

- Configuration Initiale : Sélectionnez le type de machine (2 vCPUs, 4 GB RAM), le système d'exploitation (Ubuntu 20.04 LTS), et configurez le disque persistant (30 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.5 à la VM.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

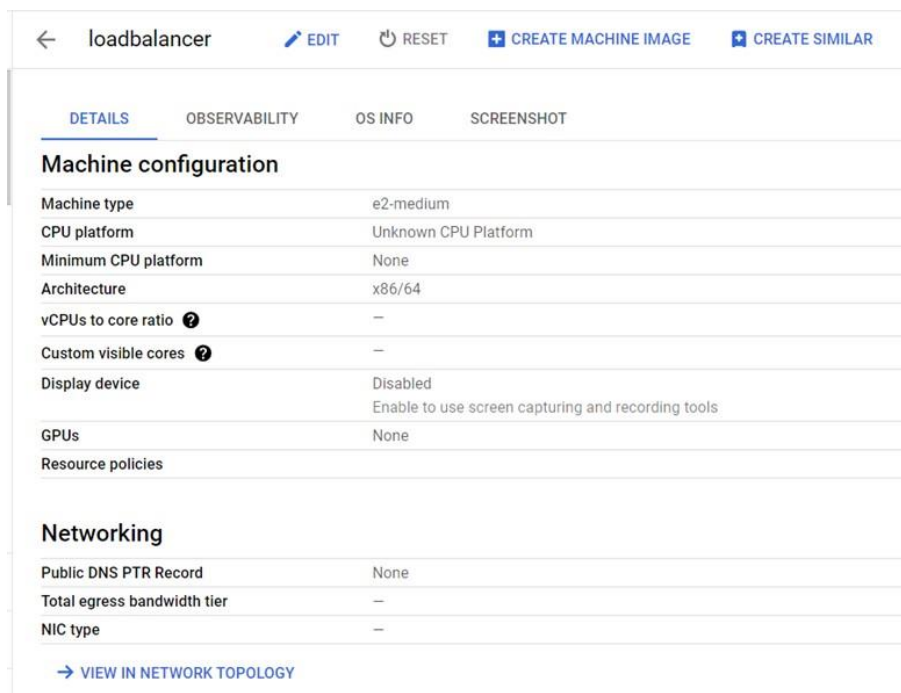


FIGURE A.5 – Vm load balancer

PfSense

- Configuration Initiale : Sélectionnez le type de machine (4 vCPUs, 2 GB RAM) configurez le disque persistant (10 GB).
- Importation : Importez l'image PfSense personnalisée.
- Réseau : Attribuez les adresses IP 192.168.0.38.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

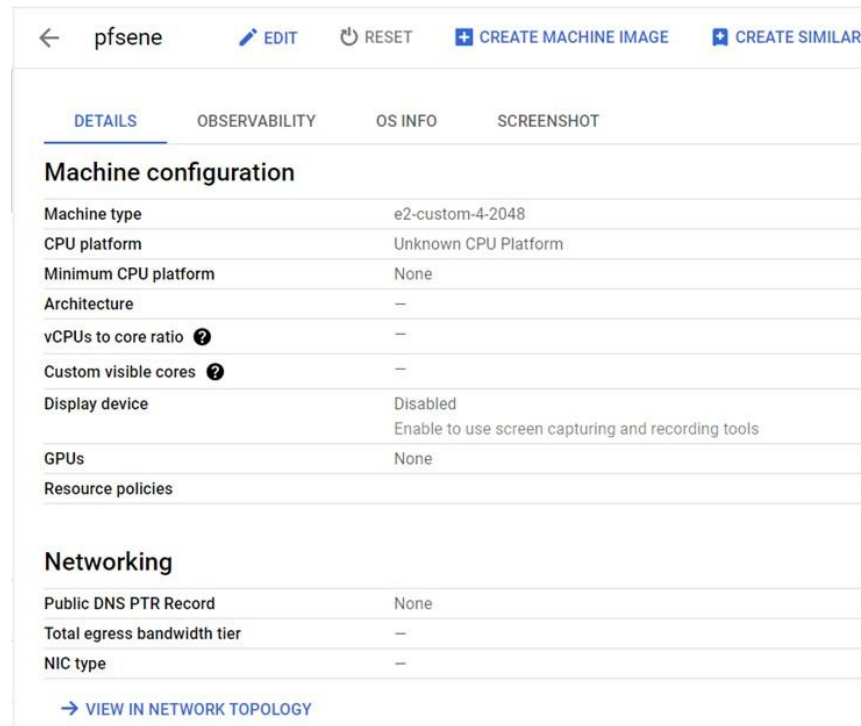


FIGURE A.6 – Vm Pfsense

Suricata

- Configuration Initiale : Sélectionnez le type de machine (2 vCPUs, 4 GB RAM), le système d'exploitation (Ubuntu 22.04 LTS), et configurez le disque persistant (30 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.9.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

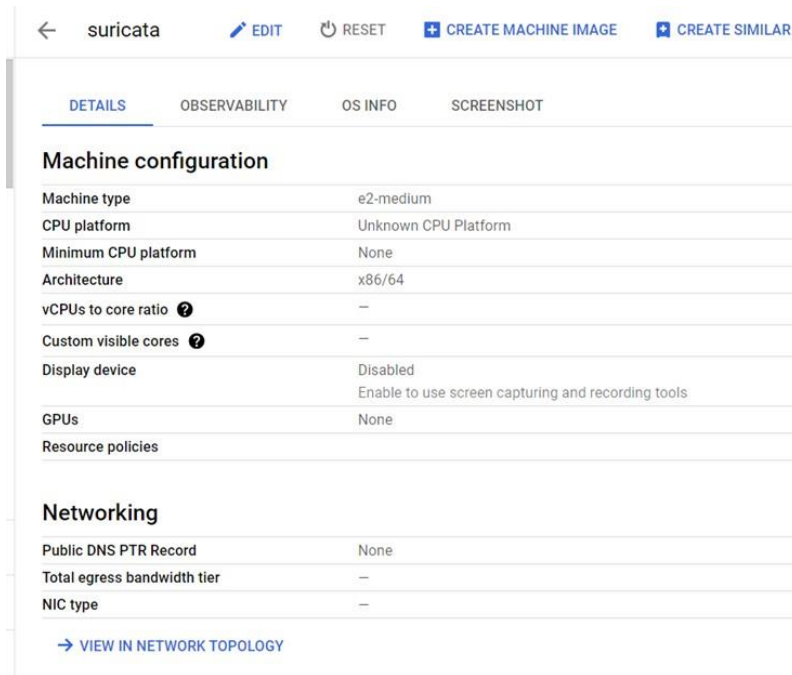


FIGURE A.7 – Vm Suricata

Cortex

- Configuration Initiale : Sélectionnez le type de machine (4 vCPUs, 16 GB RAM), le système d'exploitation (Ubuntu 22.04 LTS), et configurez le disque persistant (20 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.36.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

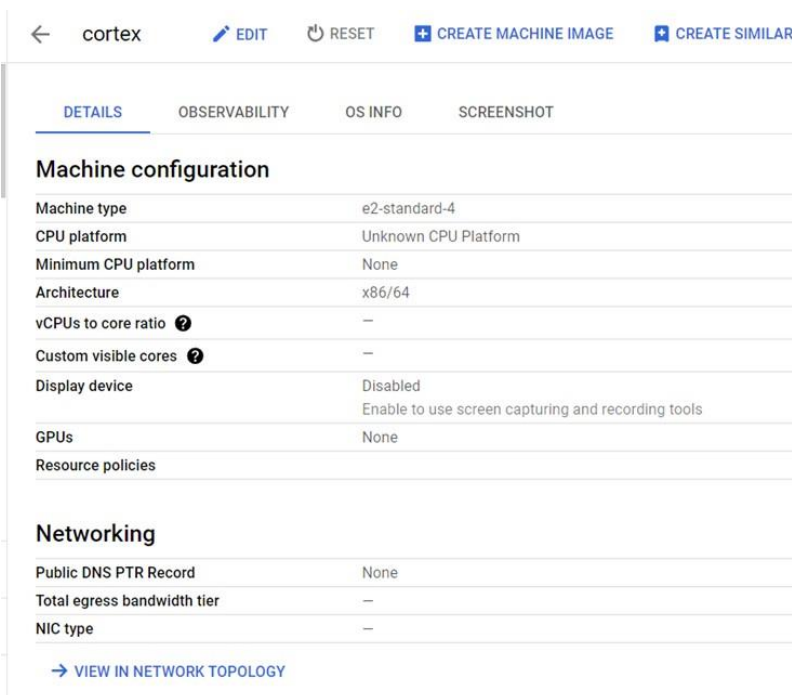


FIGURE A.8 – Vm Cortex

TheHive & MISP

- Configuration Initiale : Sélectionnez le type de machine (4 vCPUs, 16 GB RAM), le système d'exploitation (Ubuntu 20.04 LTS), et configurez le disque persistant (35 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.26.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

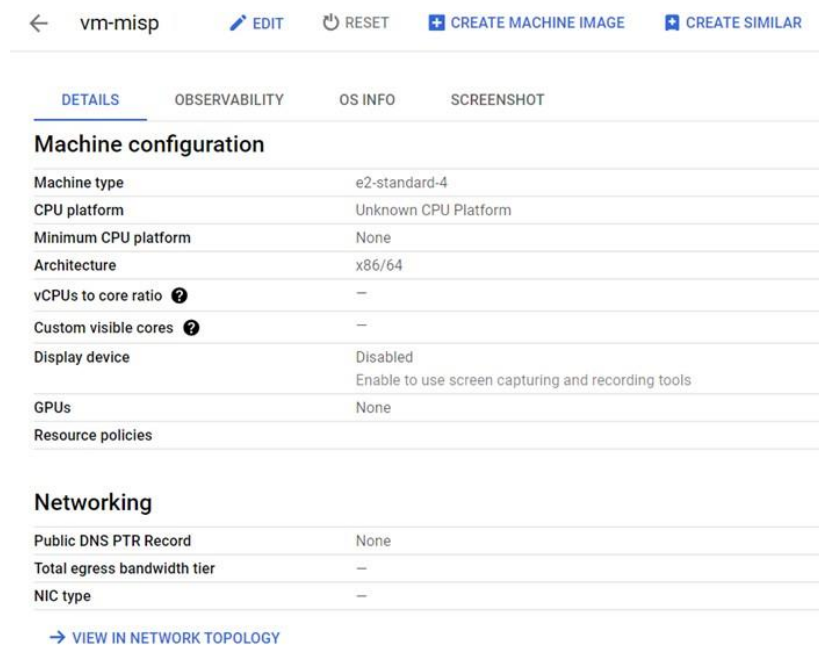


FIGURE A.9 – Vm TheHive & MISP

Agent 1

- Configuration Initiale : Sélectionnez le type de machine (2 vCPUs, 4 GB RAM), le système d'exploitation (Ubuntu 20.04 LTS), et configurez le disque persistant (15 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.4.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

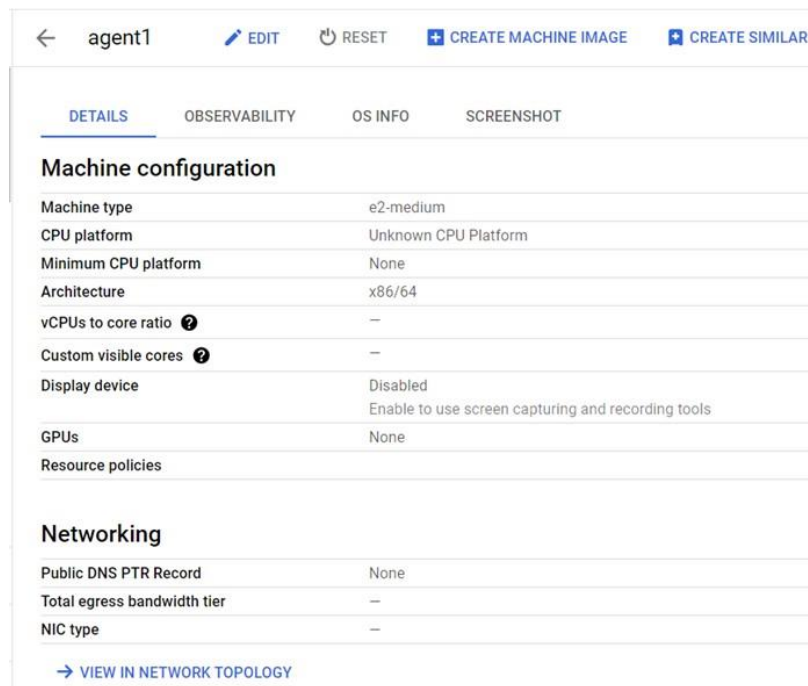


FIGURE A.10 – Vm Agent 1

Agent 2

- Configuration Initiale : Sélectionnez le type de machine (2 vCPUs, 8 GB RAM), le système d'exploitation (Windows Server 2019), et configurez le disque persistant (50 GB).
- Réseau : Attribuez l'adresse IP 192.168.0.56.
- Déploiement : Cliquez sur "Créer" pour déployer la VM.

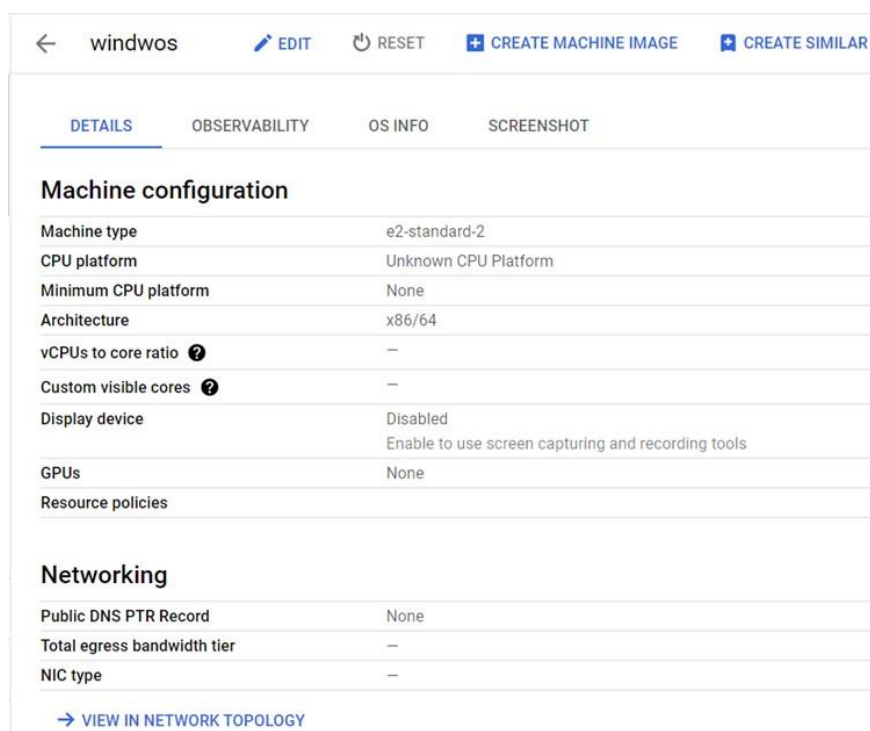


FIGURE A.11 – Vm agent 2

Annexe B : Installation du Gestionnaire de Cluster Wazuh (Manager)

Installation des Workers Wazuh

Comme pour le gestionnaire, la commande "sudo curl -sO https://packages.wazuh.com/4.4/wazuh-install.sh sudo bash ./wazuh-install.sh -a" est utilisée pour installer les workers Wazuh. Cela garantit une configuration cohérente et une intégration fluide avec le gestionnaire.

```
rabebjerbi031@worker:~$ sudo systemctl status wazuh-manager.service
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2024-04-26 12:47:17 UTC; 13min ago
     Tasks: 116 (limit: 4680)
```

FIGURE A.12 – Installation des Workers Wazuh

La commande sudo systemctl status wazuh-manager est également utilisée pour vérifier l'état des services Wazuh Manager sur les workers. L'état "active (running)" indique que les workers Wazuh sont correctement installés et opérationnels, prêts à collaborer avec le gestionnaire pour une gestion efficace des logs et des alertes.

```
rabebjerbi031@worker:~$ sudo curl -sO https://packages.wazuh.com/4.4/wazuh-install.sh && sudo bash ./wazuh-install.sh
-a
26/04/2024 12:42:34 INFO: Starting Wazuh installation assistant. Wazuh version: 4.4.5
26/04/2024 12:42:34 INFO: Verbose logging redirected to /var/log/wazuh-install.log
```

FIGURE A.13 – Status de Wazuh master

Installation et Configuration de Nginx Load Balancer pour un Cluster Wazuh

Pour assurer une répartition équitable de la charge entre les différents nœuds du cluster Wazuh, nous avons installé et configuré Nginx comme équilibreur de charge.

Installation de Nginx

```
sudo apt-get install nginx
```

```
All packages are up to date.
rabebjerbi031@loadbalancer:~$ sudo apt-get install nginx
Reading package lists... Done
Building dependency tree
Reading state information... Done
```

FIGURE A.14 – Installation de Nginx

Vérification de l'installation

```
sudo nginx -v sudo nginx -t
```

```
rabebjerbi031@loadbalancer:~$ sudo nginx -v
nginx version: nginx/1.18.0 (Ubuntu)
rabebjerbi031@loadbalancer:~$ sudo nginx -t
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
rabebjerbi031@loadbalancer:~$
```

FIGURE A.15 – Verification de Nginx

Activation de Nginx au démarrage

```
sudo systemctl enable nginx sudo systemctl status nginx
```

```
rabebjerbi031@loadbalancer:~$ sudo systemctl enable nginx
Synchronizing state of nginx.service with SysV service script with /lib/systemd/systemd-sysv-
install.
Executing: /lib/systemd/systemd-sysv-install enable nginx
rabebjerbi031@loadbalancer:~$ sudo systemctl start nginx
rabebjerbi031@loadbalancer:~$ sudo systemctl status nginx
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/lib/systemd/system/nginx.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2024-04-26 13:26:17 UTC; 1min 52s ago
```

FIGURE A.16 – Status de Nginx

Installation et Configuration d'un Cluster Wazuh

Le cluster Wazuh est essentiel pour centraliser la gestion des logs et des alertes. Nous avons installé le gestionnaire Wazuh ainsi que les workers.

Installation du Gestionnaire de Cluster Wazuh (Manager)

```
"sudo curl -sO https://packages.wazuh.com/4.4/wazuh-install.sh sudo bash ./wazuh-
install.sh -a"
```

```
rabebjerbi031@master:~$ sudo curl -sO https://packages.wazuh.com/4.4/wazuh-install.sh && sudo
bash ./wazuh-install.sh -a
26/04/2024 12:39:59 INFO: Starting Wazuh installation assistant. Wazuh version: 4.4.5
26/04/2024 12:39:59 INFO: Verbose logging redirected to /var/log/wazuh-install.log
26/04/2024 12:40:19 INFO: --- Dependencies ---
```

FIGURE A.17 – Installation de Wazuh

Vérification de l'installation de manager wazuh

sudo systemctl status wazuh-manager

```
rabebjerbi031@master:~$ sudo systemctl status wazuh-manager.service
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enable>
   Active: active (running) since Fri 2024-04-26 12:44:54 UTC; 11min ago
     Tasks: 116 (limit: 4680)
    Memory: 249.6M
```

FIGURE A.18 – Status de wazuh manager

Les mêmes étapes de l'installation pour les Wazuh Workers

```
rabebjerbi031@worker:~$ sudo curl -sO https://packages.wazuh.com/4.4/wazuh-install.sh && sudo bash ./wazuh-install.sh
-a
26/04/2024 12:42:34 INFO: Starting Wazuh installation assistant. Wazuh version: 4.4.5
26/04/2024 12:42:34 INFO: Verbose logging redirected to /var/log/wazuh-install.log
26/04/2024 12:42:53 INFO: --- Dependencies ---
```

FIGURE A.19 – installation de Wazuh Worker 1

```
rabebjerbi031@worker:~$ sudo systemctl status wazuh-manager.service
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2024-04-26 12:47:17 UTC; 13min ago
     Tasks: 116 (limit: 4680)
    Memory: 237.7M
```

FIGURE A.20 – Status de Worker 1

Configuration des Nœuds du Cluster

Modification du fichier de configuration /var/ossec/etc/ossec.conf

Clé sécurisée et partagée pour sécuriser la communication entre les nœuds du cluster

```
<cluster>
  <name>wazuh</name>
  <node_name>master-node</node_name>
  <node_type>master</node_type>
  <key>bf1d783e690023c2d95899f023d520ba</key>
  <port>1516</port>
  <bind_addr>0.0.0.0</bind_addr>
  <nodes>
    <node>192.168.10.2</node>
  </nodes>
  <hidden>no</hidden>
  <disabled>no</disabled>
</cluster>
```

FIGURE A.21 – Fichier de configuration

Redémarrage des services Wazuh

sudo systemctl restart wazuh-manager sudo systemctl status wazuh-manager

```

rabebjerbi031@master:~$ sudo systemctl restart wazuh-manager.service
rabebjerbi031@master:~$ sudo systemctl status wazuh-manager.service
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/lib/systemd/system/wazuh-manager.service; enabled; vendor preset: enable)
   Active: active (running) since Fri 2024-04-26 13:14:00 UTC; 6s ago

```

FIGURE A.22 – Status de wazuh manager

Configuration de wazuh workers

```

<cluster>
  <name>wazuh</name>
  <node_name>worker2</node_name>
  <node_type>worker</node_type>
  <key>bf1d783e690023c2d95899f023d520ba</key>
  <port>1516</port>
  <bind_addr>0.0.0.0</bind_addr>
  <nodes>
    <node>192.168.10.2</node>
  </nodes>
  <hidden>no</hidden>
  <disabled>no</disabled>
</cluster>

```

FIGURE A.23 – Fichier de configuration

La même configuration pour le worker2

Test de cluster

```

worker2      worker  4.7.4    192.168.0.31
rabebjerbi031@master:~$ sudo /var/ossec/bin/cluster_control -l
NAME          TYPE      VERSION  ADDRESS
master-node   master    4.7.4    192.168.10.2
worker2       worker    4.7.4    192.168.0.31
worker1-node  worker    4.7.4    192.168.0.3
rabebjerbi031@master:~$

```

FIGURE A.24 – Résultat de test

Installation et Configuration de MISP

MISP permet le partage de renseignements sur les menaces. Son intégration avec Wazuh et TheHive enrichit notre capacité de détection et de réponse.

Installation de MISP

```
wget --no-cache -O /tmp/INSTALL.sh https://raw.githubusercontent.com/MISP/MISP/2.4/INSTALL.sh
bash /tmp/INSTALL.sh -c
```

```
rabebjerbi031@vm:~$ sudo wget --no-cache -O /tmp/INSTALL.sh https://raw.githubusercontent.com/MISP/MISP/2.4/INSTALL.sh
--2024-05-14 16:56:18-- https://raw.githubusercontent.com/MISP/MISP/2.4/INSTALL/INSTALL.sh
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.111.133, 185.199.109.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 161265 (157K) [text/plain]
Saving to: '/tmp/INSTALL.sh'

/tmp/INSTALL.sh      100%[=====>] 157.49K  --.-KB/s   in 0.05s

2024-05-14 16:56:19 (3.37 MB/s) - '/tmp/INSTALL.sh' saved [161265/161265]

rabebjerbi031@vm:~$ bash /tmp/INSTALL.sh -c
Next step: Checking if we are run as the installer template
Next step: Checking Linux distribution and flavour...
Next step: We detected the following Linux flavour: Ubuntu 20.04
Next step: Checking if we are uptodate and checksums match
sha1 matches
sha256 matches
sha384 matches
sha512 matches
-----
Next step: Setting MISP variables
Next step: Setting generic MISP variables shared by all flavours
groups: 'misp': no such user
The following DB Passwords were generated...
Admin (root) DB Password: 9aec5f95568bdc42d101042fb8e9a831ea12b219e960a2bca82bcea460e287
User (misp) DB Password: 5752a08699211e11dae0476146cb9122849falla51652b6838a2702e101cfeb51
Next step: Checking for parameters or Unattended Kali Install
Next step: Setting install options with given parameters.
core
Install on Ubuntu 20.04 LTS fully supported.
Please report bugs/issues here: https://github.com/MISP/MISP/issues
```

FIGURE A.25 – Installation de MISP

Changer le mot de passe administrateur

Initial Install, please configure



Welcome to MISP on ubuntu, change this message in MISP Settings

Login

Email

Password

Login

FIGURE A.26 – interface de MISP

Création d'une organisation

Organisation pfe-soc

ID	2
UUID	a54676c6-9241-4556-8929-80376a29e29d
Local or remote	Local
Created by	admin@admin.test
Creation time	2024-05-14 17:09:55
Last modified	2024-05-14 17:09:55
Nationality	 Tunisia
Sector	Soc
Organisation type	Open Source

[Members](#) [Events](#) [Sharing Groups](#)

FIGURE A.27 – Création d'une organisation

Création d'un utilisateur

Admin Add User

Email

☒ Set password

Password ? Confirm Password

Organisation

Role NIDS SID

Sync user for

PGP key
 Paste the user's PGP key here or try to retrieve it from the CIRCL key server by clicking on "Fetch PGP key" below.

Fetch PGP key

FIGURE A.28 – Création d'un utilisateur

Activation des flux de renseignements sur les menaces

Default feeds Custom feeds All feeds Enabled feeds							Enter value to search Filter		
☐	ID	Enabled	Caching	Name	Format	Provider	Org	Source	URL
☐	1	x	x	CIRCL OSINT Feed	misp	CIRCL	network	https://www.circl.lu/doc/misp/feed	
☐	2	x	x	The Botvrij eu Data	misp	Botvrij eu	network	https://www.botvrij.eu/data/feed	
☐	3	x	x	ELLIO: IP Feed (Community version)	freetext	ellio tech	network	https://cdn.ellio.tech/community-f	
☐	4	x	x	blockrules of rules.emergingthreats.net	csv	rules.emergingthreats.net	network	https://rules.emergingthreats.net/ips.txt	
☐	5	x	x	Tor exit nodes	csv	TOR Node List from dan.me.uk - careful, this feed applies a lock-out after each pull. This is shared with the "Tor ALL nodes" feed.	network	https://www.dan.me.uk/torlist/7ex	
☐	6	x	x	Tor ALL nodes	csv	TOR Node List from dan.me.uk - careful, this feed applies a lock-out after each pull. This is shared with the "Tor exit nodes" feed.	network	https://www.dan.me.uk/torlist/	
☐	7	x	x	cybercrime-tracker.net - all	freetext	cybercrime-tracker.net	network	https://cybercrime-tracker.net/all	
☐	8	x	x	Phishtank online valid phishing	csv	Phishtank	network	https://data.phishtank.com/data/c	
☐	9	x	x	ip-block-list - snort.org	freetext	https://snort.org	network	https://snort.org/downloads/ip-bk	
☐	10	x	x	diamondfox_panels	freetext	pan-unit42	network	https://raw.githubusercontent.com/unit42/ocs/master/diamondfox/d	

FIGURE A.29 – Activation de flux

Installation de TheHive

```
wget -q -O /tmp/install.sh https://archives.strangebee.com/scripts/install.sh ; sudo -v ;
bash /tmp/install.sh
```

```
TheHive installation is complete!  
  
Connect to http://192.168.0.26:9000 and start configuring the application. Create a global Admin account, and then Organisations and users.  
  
Information:  
TheHive is installed with basic configuration parameters. It is configured to use local accounts for authentication ;
```

FIGURE A.30 – Installation de TheHive

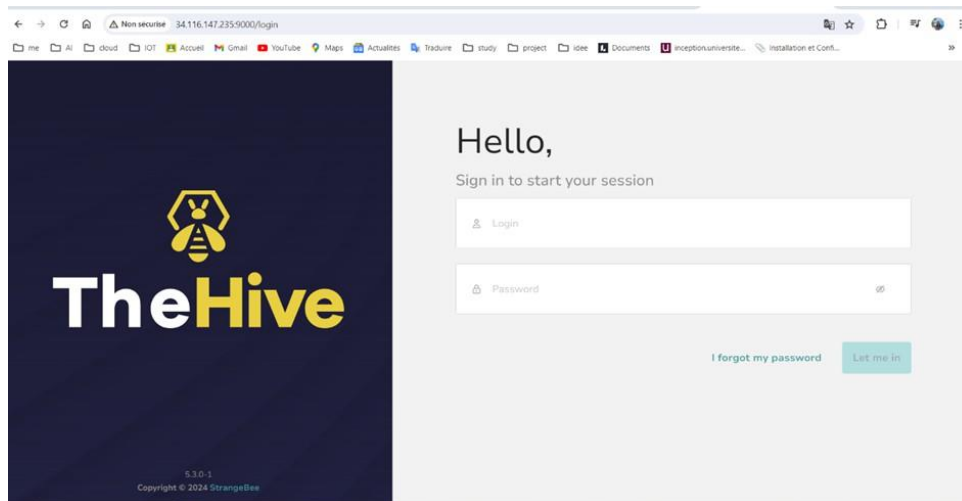


FIGURE A.31 – L'interfacé de TheHive

Création d'une organisation

Adding an Organisation

*

Name

pfe-soc

*

Description

pfe organisation

Tasks sharing rule

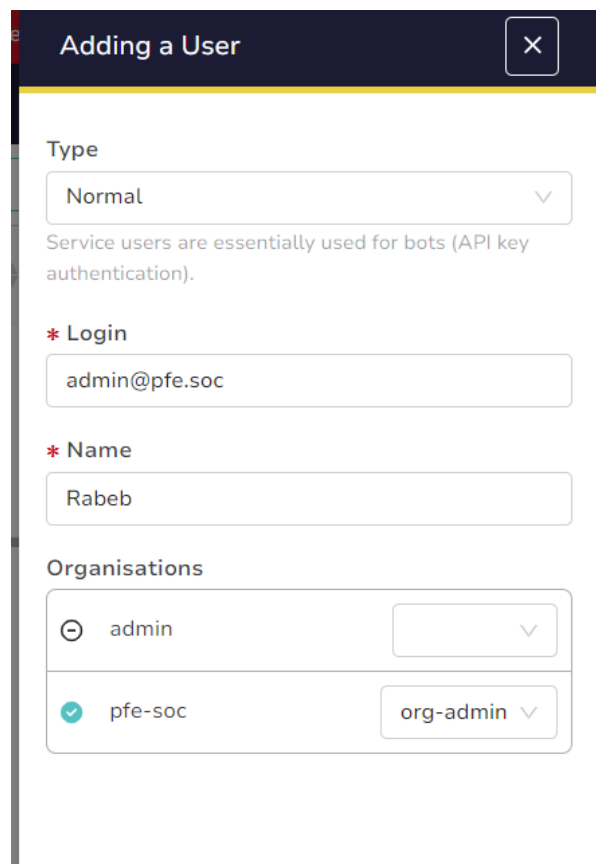
autoShare

Observables sharing rule

autoShare

FIGURE A.32 – Création d'une organisation

Création d'un utilisateur



The screenshot shows a modal window titled "Adding a User" with a close button (X) in the top right corner. The form contains the following fields and sections:

- Type:** A dropdown menu with "Normal" selected.
- Service users:** A note stating "Service users are essentially used for bots (API key authentication)."
- * Login:** A text input field containing "admin@pfe.soc".
- * Name:** A text input field containing "Rabeb".
- Organisations:** A section with two rows:
 - Row 1: A radio button (unselected) next to "admin" and a dropdown menu.
 - Row 2: A radio button (selected) next to "pfe-soc" and a dropdown menu with "org-admin" selected.

FIGURE A.33 – Création d'un utilisateur

Intégration de MISP avec Wazuh

Téléchargement du script custom-misp.py

```

rabebjerbi031@master:~$ sudo /var/ossec/framework/python/bin/pip3 install thehive4py==1.8.1
Collecting thehive4py==1.8.1
  Downloading thehive4py-1.8.1-py3-none-any.whl.metadata (4.3 kB)
Requirement already satisfied: future in /var/ossec/framework/python/lib/python3.9/site-packages (from thehive4py==1.8.1) (0.18.3)
Requirement already satisfied: requests in /var/ossec/framework/python/lib/python3.9/site-packages (from thehive4py==1.8.1) (2.31.0)
Collecting python-magic (from thehive4py==1.8.1)
  Downloading python_magic-0.4.27-py2.py3-none-any.whl.metadata (5.8 kB)
Requirement already satisfied: charset-normalizer<4,>=2 in /var/ossec/framework/python/lib/python3.9/site-packages (from requests->thehive4py==1.8.1) (2.0.4)
Requirement already satisfied: idna<4,>=2.5 in /var/ossec/framework/python/lib/python3.9/site-packages (from requests->thehive4py==1.8.1) (2.9)
Requirement already satisfied: urllib3<3,>=1.21.1 in /var/ossec/framework/python/lib/python3.9/site-packages (from requests->thehive4py==1.8.1) (1.26.5)
Requirement already satisfied: certifi>=2017.4.17 in /var/ossec/framework/python/lib/python3.9/site-packages (from requests->thehive4py==1.8.1) (2023.7.22)
Downloading thehive4py-1.8.1-py3-none-any.whl (32 kB)
Downloading python_magic-0.4.27-py2.py3-none-any.whl (13 kB)
Installing collected packages: python-magic, thehive4py
Successfully installed python-magic-0.4.27 thehive4py-1.8.1
WARNING: Running pip as the 'root' user can result in broken permissions and conflicting behaviour with the system package manager. It is recommended to use a virtual environment instead: https://pip.pypa.io/warnings/venv

[notice] A new release of pip is available: 23.3.2 -> 24.0
[notice] To update, run: /var/ossec/framework/python/bin/python3.9 -m pip install --upgrade pip
rabebjerbi031@master:~$

```

FIGURE A.34 – Téléchargement du script

Configuration de l'intégration dans ossec.conf

```

...
GNU nano 4.8 /var/ossec/integrations/custom-w2hive.py Modified
#!/var/ossec/framework/python/bin/python3
import json
import sys
import os
import re
import logging
import uuid
from thehive4py.api import TheHiveApi
from thehive4py.models import Alert, AlertArtifact

#start user config

# Global vars

#threshold for wazuh rules level
lvl_threshold=0
#threshold for suricata rules level
suricata_lvl_threshold=3

debug_enabled = False
#info about created alert
info_enabled = True

#end user config

# Set paths
pwd = os.path.dirname(os.path.dirname(os.path.realpath(__file__)))
log_file = '{0}/logs/integrations.log'.format(pwd)
logger = logging.getLogger(__name__)
#set logging level
logger.setLevel(logging.WARNING)
if info_enabled:
    logger.setLevel(logging.INFO)
if debug_enabled:
    logger.setLevel(logging.DEBUG)
# create the logging file handler
fh = logging.FileHandler(log_file)
formatter = logging.Formatter('%(asctime)s - %(name)s - %(levelname)s - %(message)s')
fh.setFormatter(formatter)
logger.addHandler(fh)

```

FIGURE A.35 – configuration de ossec.conf

Création de règles personnalisées pour MISP

```

GNU nano 4.8 /var/ossec/integrations/custom-w2thive Modified
#!/bin/sh
# Copyright (C) 2015-2020, Wazuh Inc.
# Created by Wazuh, Inc. <info@wazuh.com>.
# This program is free software; you can redistribute it and/or modify it under the terms of

WPYTHON_BIN="framework/python/bin/python3"

SCRIPT_PATH_NAME="$0"

DIR_NAME="(cd $(dirname ${SCRIPT_PATH_NAME}); pwd -P)"
SCRIPT_NAME="(basename ${SCRIPT_PATH_NAME})"

case ${DIR_NAME} in
  */active-response/bin | */wodles*)
    if [ -z "${WAZUH_PATH}" ]; then
      WAZUH_PATH="(cd ${DIR_NAME}/../..; pwd)"
    fi

    PYTHON_SCRIPT="${DIR_NAME}/${SCRIPT_NAME}.py"
    ;;
  */bin)
    if [ -z "${WAZUH_PATH}" ]; then
      WAZUH_PATH="(cd ${DIR_NAME}/../; pwd)"
    fi

    PYTHON_SCRIPT="${WAZUH_PATH}/framework/scripts/${SCRIPT_NAME}.py"
    ;;
  */integrations)
    if [ -z "${WAZUH_PATH}" ]; then
      WAZUH_PATH="(cd ${DIR_NAME}/../; pwd)"
    fi

    PYTHON_SCRIPT="${DIR_NAME}/${SCRIPT_NAME}.py"
    ;;
esac

${WAZUH_PATH}/${WPYTHON_BIN} ${PYTHON_SCRIPT} $@

```

FIGURE A.36 – Les règles de MISP

Intégration de TheHive avec MISP

Set up the new server

General settings

- * Server name: misp
- * Server url: https://34.118.33.143
- * API Key: [masked]
- * Purpose: Import and export

Proxy

Use default configuration: **Enabled** | Disabled

SSL Settings

Check Certificate Authority: ☒

FIGURE A.37 – Intégration de TheHive avec MISP

Résultat de l'intégration

Lette instance utilise une licence Platinum à des fins d'essai et expirera dans 15 jours. S'inscrire maintenant.

Alertes

Entrez un numéro de dossier

+ Créer un cas

→ défaut Filtres rapides Exporter la liste

Statut	Gravité	Titre	# Cas	Taper	Source	Référence	Détails	Cessionnaire	Rendez-vous
Nouveau	M	L'état des ports écoutés (netstat) a changé (nouveau port ouvert ou fermé).	1	wazuh_alert	wazuh	dddbc9	Observables TTP	58 0	O. 14/05/2024 19:12 C. 14/05/2024 19:12 U. 14/05/2024 19:12
Nouveau	M	PAM : session de connexion fermée.	1	wazuh_alert	wazuh	3278e0	Observables TTP	0 0	O. 14/05/2024 19:06 C. 14/05/2024 19:06
Nouveau	M	PAM : session de connexion ouverte.	1	wazuh_alert	wazuh	b63527	Observables TTP	0 0	O. 14/05/2024 19:06 C. 14/05/2024 19:06

succès
L'utilisateur a modifié avec succès !

Précédent 0 - 7 sur 7 Suivant Montrer 30

FIGURE A.38 – Résultat de l'intégration

Installation de cortex

```
wget -q -O /tmp/install.sh https://archives.strangebee.com/scripts/install.sh ; sudo -v ;  
bash /tmp/install.sh
```

```
TheHive & Cortex installation script, for Linux operating systems with DEB or RPM packages.  
This script supports the installation of TheHive on x86_64 and ARM servers, and Cortex on x86_64 only.  
  
Following install options are available:  
- Configure proxy settings  
- Install TheHive 5.3 (x86_64 or ARM)  
- Install Cortex (running Analyzers and Responders with Docker) (x86_64 only)  
- Install Cortex (running Analyzers and Responders on the host -- Not recommended, supported on Ubuntu and Debian ONLY) (x86_64 only)  
  
This script has successfully been tested on freshly installed Operating Systems:  
- Fedora 35 & 37  
- RHEL 8.5 9.3  
- Ubuntu 20.04 LTS & 22.04 LTS  
- Debian 11  
  
Requirements:  
- 4vCPU  
- 16 GB of RAM  
  
Usage:  
  
$ wget -q -O /tmp/install.sh https://archives.strangebee.com/scripts/install.sh ; sudo -v ;  
bash /tmp/install.sh  
  
Maintained by: @StrangeBee - https://www.strangebee.com  
  
---  
  
1) Setup proxy settings  
2) Install TheHive  
3) Install Cortex (run Neurons with docker)  
4) Install Cortex (run Neurons locally)  
5) Quit  
Select an option: 4
```

FIGURE A.39 – Installation de cortex

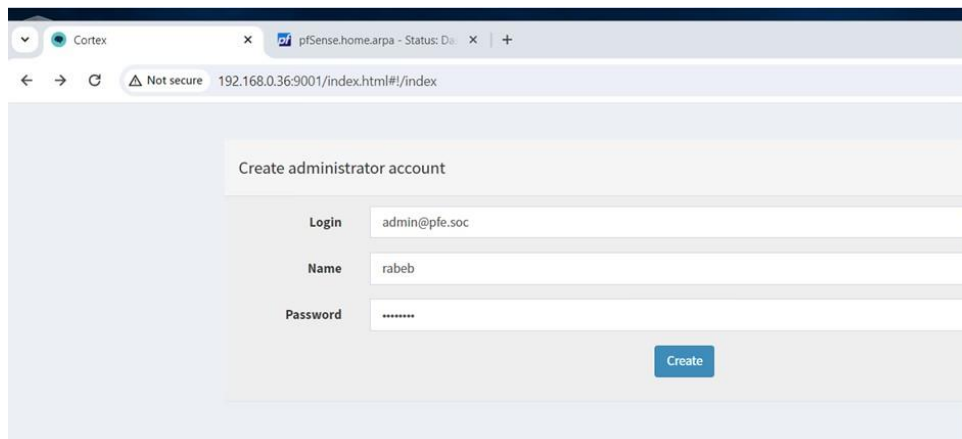


FIGURE A.40 – L'interface de cortex

Création d'une organisation

The screenshot shows the Cortex web interface with a modal titled "Create organization". The modal contains two input fields: "Name" with the value "XDR" and "Description" with the value "XDR SOC". Below the fields are "Cancel" and "Save" buttons. A red asterisk and the text "Required field" are visible at the bottom left of the modal.

FIGURE A.41 – Création d'une organisation

Création d'un utilisateur

The screenshot shows the Cortex web interface with a modal titled "Add user". The modal contains three input fields: "Login" with the value "rabe@pfe.soc", "Full name" with the value "rabe", and "Roles" with a dropdown menu showing "read, analyze, orgadmin". Below the fields are "Cancel" and "Save user" buttons. A red asterisk and the text "Required field" are visible at the bottom left of the modal.

FIGURE A.42 – Création d'un utilisateur

Integration de thehive avec cortex

The screenshot shows the TheHive web interface with the integration configuration page. The page displays the TheHive logo and configuration details for Cortex, MISP, and Email Intake. The Cortex version is 3.1.0-1, MISP version is 2.4.192, and the Email Intake is configured with the URL https://192.168.0.26. The License section shows a Platinum plan with an expiration date of 29/05/2024 23:59.

FIGURE A.43 – Integration de thehive avec cortex

Agent 1

installation de l'agent 1

```
rabebjerbi031@agent1:~$ curl -o wazuh-agent-4.7.4-1.x86_64.rpm https://packages.wazuh.com/4.x/yum/wazuh-agent-4.7.4-1.x86_64
.rpm && sudo WAZUH_MANAGER='192.168.10.2' WAZUH_AGENT_GROUP='default' WAZUH_AGENT_NAME='agent1' rpm -ihv wazuh-agent-4.7.4-1
.x86_64.rpm
```

FIGURE A.44 – installation de l'agent 1

status de l'agent1

```
rabebjerbi031@agent1:~$ sudo systemctl daemon-reload
rabebjerbi031@agent1:~$ sudo systemctl enable wazuh-agent
rabebjerbi031@agent1:~$ sudo systemctl start wazuh-agent
rabebjerbi031@agent1:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/lib/systemd/system/wazuh-agent.service; enabled; vendor preset: enabled)
   Active: active (running) since Wed 2024-05-22 11:33:24 UTC; 17s ago
     Process: 3750 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, status=0/SUCCESS)
    Tasks: 5 (limit: 4680)
   Memory: 180.2M
    CGroup: /system.slice/wazuh-agent.service
            └─3772 /var/ossec/bin/wazuh-execd
               4262 /bin/sh active-response/bin/restart.sh agent
               4266 /bin/sh /var/ossec/bin/wazuh-control restart
               4374 sleep 0.1

May 22 11:33:17 agent1 systemd[1]: Starting Wazuh agent...
May 22 11:33:17 agent1 env[3750]: Starting Wazuh v4.7.4...
May 22 11:33:18 agent1 env[3750]: Started wazuh-execd...
May 22 11:33:19 agent1 env[3750]: Started wazuh-agentd...
May 22 11:33:20 agent1 env[3750]: Started wazuh-syscheckd...
May 22 11:33:21 agent1 env[3750]: Started wazuh-logcollector...
May 22 11:33:22 agent1 env[3750]: Started wazuh-modulesd...
May 22 11:33:24 agent1 env[3750]: Completed.
May 22 11:33:24 agent1 systemd[1]: Started Wazuh agent.
rabebjerbi031@agent1:~$
```

FIGURE A.45 – status de l'agent1

Agent2

installation de l'agent 1

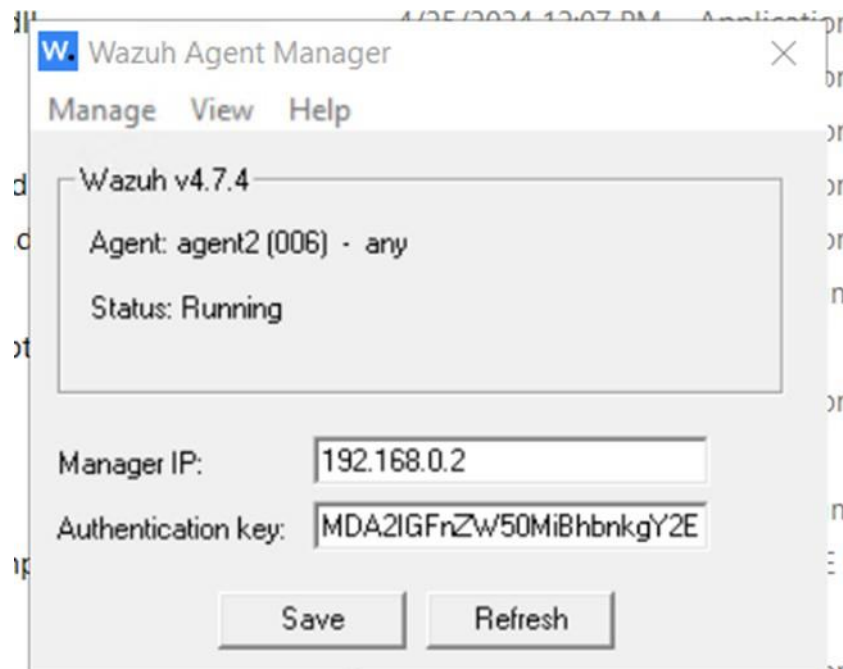


FIGURE A.46 – installation de l'Agent2

Status de l'agent 2

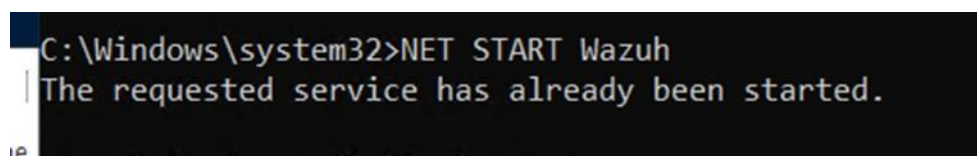


FIGURE A.47 – Status de l'agent 2

Integration de suricata avec wazuh

La surveillance du trafic réseau offre une visibilité précieuse sur les menaces. On a intégré l'IDS Suricata avec Wazuh pour combiner les capacités de détection réseau et de point de terminaison. L'intégration permet de corréler les analyses de trafic de Suricata avec les événements de sécurité des endpoints.

Configuration de l'endpoint Ubuntu

Pour configurer Suricata sur l'endpoint Ubuntu et envoyer les journaux générés au serveur Wazuh, on a installé le wazuh agent sur cette machine

```

rabebjerbi031@suricata:~$ wget https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazu
h-agent_4.7.4-1_amd64.deb && sudo WAZUH_MANAGER='192.168.0.2' WAZUH_AGENT_GROUP='default' WAZU
H_AGENT_NAME='suricata' dpkg -i ./wazuh-agent_4.7.4-1_amd64.deb
--2024-05-07 20:41:00-- https://packages.wazuh.com/4.x/apt/pool/main/w/wazuh-agent/wazuh-agen
t_4.7.4-1_amd64.deb
Resolving packages.wazuh.com (packages.wazuh.com)... 18.244.102.124, 18.244.102.16, 18.244.102
.6, ...
Connecting to packages.wazuh.com (packages.wazuh.com)|18.244.102.124|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 9372734 (8.9M) [binary/octet-stream]
Saving to: 'wazuh-agent_4.7.4-1_amd64.deb'

wazuh-agent_4.7.4-1_amd 100%[=====>] 8.94M --.-KB/s in 0.03s

2024-05-07 20:41:00 (262 MB/s) - 'wazuh-agent_4.7.4-1_amd64.deb' saved [9372734/9372734]

Selecting previously unselected package wazuh-agent.
(Reading database ... 66320 files and directories currently installed.)
Preparing to unpack .../wazuh-agent_4.7.4-1_amd64.deb ...
Unpacking wazuh-agent (4.7.4-1) ...
Setting up wazuh-agent (4.7.4-1) ...
rabebjerbi031@suricata:~$

```

FIGURE A.48 – installation de l'Agent Suricata

Status de l'agent suricata

```

rabebjerbi031@suricata:~$ sudo systemctl daemon-reload
rabebjerbi031@suricata:~$ sudo systemctl enable wazuh-agent
Created symlink /etc/systemd/system/multi-user.target.wants/wazuh-agent.service → /lib/systemd
/system/wazuh-agent.service.
rabebjerbi031@suricata:~$ sudo systemctl start wazuh-agent
rabebjerbi031@suricata:~$ sudo systemctl status wazuh-agent
● wazuh-agent.service - Wazuh agent
   Loaded: loaded (/lib/systemd/system/wazuh-agent.service; enabled; vendor preset: enabled)
   Active: active (running) since Tue 2024-05-07 20:42:09 UTC; 24s ago
     Process: 2421 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (code=exited, sta
   Tasks: 35 (limit: 4675)
    Memory: 258.9M
         CPU: 13.822s
    CGroup: /system.slice/wazuh-agent.service
            └─2928 /bin/sh active-response/bin/restart.sh agent
            └─2932 /bin/sh /var/ossec/bin/wazuh-control restart
            └─3066 /var/ossec/bin/wazuh-execd
            └─3077 /var/ossec/bin/wazuh-agentd
            └─3091 /var/ossec/bin/wazuh-syscheckd
            └─3105 /var/ossec/bin/wazuh-logcollector
            └─3123 /var/ossec/bin/wazuh-modulesd
            └─3330 sleep 2
            └─3355 /usr/bin/python3 /usr/sbin/ufw status

May 07 20:42:01 suricata systemd[1]: Starting Wazuh agent...
May 07 20:42:01 suricata env[2421]: Starting Wazuh v4.7.4...
May 07 20:42:02 suricata env[2421]: Started wazuh-execd...
May 07 20:42:04 suricata env[2421]: Started wazuh-agentd...
May 07 20:42:05 suricata env[2421]: Started wazuh-syscheckd...
May 07 20:42:06 suricata env[2421]: Started wazuh-logcollector...
May 07 20:42:07 suricata env[2421]: Started wazuh-modulesd...
May 07 20:42:09 suricata env[2421]: Completed.
May 07 20:42:09 suricata systemd[1]: Started Wazuh agent.
lines 1-27/27 (END)

```

FIGURE A.49 – Status de l'agent suricata

Integration de suricata

1 Installez Suricata sur l'endpoint Ubuntu. Nous avons testé ce processus avec la version 6.0.8 et cela peut prendre un certain temps : `sudo add-apt-repository ppa :oisf/suricata-stable`

```

rabeberbi031@suricata:~$ sudo add-apt-repository ppa:oisf/suricata-stable
Repository: 'deb https://ppa.launchpadcontent.net/oisf/suricata-stable/ubuntu/ jammy main'
Description:
Suricata IDS/IPS/NSM stable packages
https://suricata.io/
https://oisf.net/

Suricata IDS/IPS/NSM - Suricata is a high performance Intrusion Detection and Prevention System and Network Security Monitoring engine.

Open Source and owned by a community run non-profit foundation, the Open Information Security Foundation (OISF). Suricata is developed by the OISF, its supporting vendors and the community.

This Engine supports:

- Multi-Threading - provides for extremely fast and flexible operation on multicore systems.
- Multi Tenancy - Per vlan/Per interface
- Uses Rust for most protocol detection/parsing
- TLS/SSL certificate matching/logging
- JA3 TLS client fingerprinting
- JA3S TLS server fingerprinting
- IEEE 802.1ad (QinQ) and IEEE 802.1Q (VLAN) support
- VXLAN support
- All JSON output/logging capability
- IDS runmode

```

FIGURE A.50 – Integration de suricata

`sudo apt-get update` `sudo apt-get install suricata -y`

```

Reading package lists... Done
rabebjerbi031@suricata:~$ sudo apt-get update
Hit:1 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy InRelease
Hit:2 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy-updates InRelease
Hit:3 http://security.ubuntu.com/ubuntu jammy-security InRelease
Hit:4 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy-backports InRelease
Hit:5 https://ppa.launchpadcontent.net/oisf/suricata-stable/ubuntu jammy InRelease
Reading package lists... Done
rabebjerbi031@suricata:~$ sudo apt-get install suricata -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following additional packages will be installed:
  libevent-2.1-7 libevent-pthreads-2.1-7 libhiredis0.14 libhttp2 libhyperscan5
  liblua5.1-2 liblua5.1-common liblzma-dev libnet1 libnetfilter-queue1
Suggested packages:
  liblzma-doc
The following NEW packages will be installed:
  libevent-2.1-7 libevent-pthreads-2.1-7 libhiredis0.14 libhttp2 libhyperscan5
  liblua5.1-2 liblua5.1-common liblzma-dev libnet1 libnetfilter-queue1 suricata
0 upgraded, 11 newly installed, 0 to remove and 3 not upgraded.
Need to get 6406 kB of archives.
After this operation, 28.9 MB of additional disk space will be used.
Get:1 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy/universe amd64 libhyperscan5 amd64 5.4.0-2 [2485 kB]
Get:2 https://ppa.launchpadcontent.net/oisf/suricata-stable/ubuntu jammy/main amd64 libhttp2 amd64 1:0.5.48-0ubuntu2 [75.7 kB]
Get:3 https://ppa.launchpadcontent.net/oisf/suricata-stable/ubuntu jammy/main amd64 suricata amd64 1:7.0.5-0ubuntu2 [3154 kB]
Get:4 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy/main amd64 libevent-2.1-7 amd64 2.1.12-stable-1build3 [148 kB]
Get:5 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy/main amd64 libevent-pthreads-2.1-7 amd64 2.1.12-stable-1build3 [7642 B]
Get:6 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu jammy/universe amd64 libh

```

FIGURE A.51 – Installation de Suricata

Pour télécharger et extraire le jeu de règles Suricata de Emerging Threats, on a utilisé cette commande `cd /tmp/ curl -LO https://rules.emergingthreats.net/open/suricata-6.0.8/emerging.rules.tar.gz`

```

No VM guests are running outdated hypervisor (qemu) binaries on this host.
rabebjerbi031@suricata:~$ cd /tmp/ && curl -LO https://rules.emergingthreats.net/open/suricata-6.0.8/emerging.rules.tar.gz
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left  Speed
100 4171k  100 4171k    0     0  3243k      0  0:00:01  0:00:01 --:--:-- 3244k
rabebjerbi031@suricata:/tmp$ 

```

FIGURE A.52 – Téléchargement des règles Suricata

Pour le fichier de configuration "suricata.yaml", on a définie "HOME_NET" avec l'adresse IP locale de notre réseau. On a conservé le chemin par défaut pour les règles et ajouté le chemin où les règles Suricata téléchargées sont situées. Ce paramétrage permettra à Suricata de fonctionner en mode IPS dans l'interface configurée. On a exécuté la commande "`sudo suricata -T -c /etc/suricata/suricata.yaml`" pour s'assurer que tout est correct.

```

rabebjerbi031@suricata:~$ sudo suricata -T -c /etc/suricata/suricata.yaml
i: suricata: This is Suricata version 7.0.5 RELEASE running in SYSTEM mode
i: suricata: Configuration provided was successfully loaded. Exiting.
rabebjerbi031@suricata:~$ 

```

FIGURE A.53 – Verification de suricata

Après cette configuration, on a redémarré le service suricata pour appliquer les changements avec la commande "sudo systemctl restart suricata"

```
rabebjerbi031@suricata:~$ sudo nano /etc/suricata/suricata.yaml
rabebjerbi031@suricata:~$ sudo systemctl restart suricata
rabebjerbi031@suricata:~$ sudo systemctl status suricata
● suricata.service - LSB: Next Generation IDS/IPS
   Loaded: loaded (/etc/init.d/suricata; generated)
   Active: active (exited) since Wed 2024-05-08 07:46:23 UTC; 3s ago
     Docs: man:systemd-sysv-generator(8)
  Process: 2023 ExecStart=/etc/init.d/suricata start (code=exited, status=0/SUCCESS)
    CPU: 141ms

May 08 07:46:23 suricata systemd[1]: Starting LSB: Next Generation IDS/IPS...
May 08 07:46:23 suricata suricata[2023]: Likely stale PID 1995 with /var/run/suricata.pid exi
May 08 07:46:23 suricata suricata[2023]: Removing stale PID file /var/run/suricata.pid
May 08 07:46:23 suricata suricata[2023]: Starting suricata in IDS (af-packet) mode... done.
May 08 07:46:23 suricata systemd[1]: Started LSB: Next Generation IDS/IPS.
lines 1-12/12 (END)
```

FIGURE A.54 – Redémarrage de suricata

On a ajouté la configuration suivante dans le fichier de l'agent Wazuh, ce qui permet à l'agent Wazuh de lire le fichier de journaux Suricata

```
<localfile>
  <log_format>json</log_format>
  <location>/var/log/suricata/eve.json</location>
</localfile>

</ossec_config>
```

FIGURE A.55 – Configuration de suricata

On a ajouté la configuration suivante dans le fichier du manager Wazuh

```
<decoder name="local_decoder_example">
  <program_name>local_decoder_example</program_name>
</decoder>
<decoder name="json">
  <prematch>^{\s*"</prematch>
</decoder>
<decoder name="json_child">
  <parent>json</parent>
  <regex type="pcre2">"src_ip": "([^\"]+)"</regex>
  <order>srcip</order>
</decoder>
<decoder name="json_child">
  <parent>json</parent>
  <plugin_decoder>JSON_Decoder</plugin_decoder>
</decoder>
```

FIGURE A.56 – Configuration de wazuh manager

On a redémarré du manager Wazuh pour appliquer les changements.

```
rabebjerbi031@master:~$ sudo nano /var/ossec/etc/decoders/local_decoder.xml
rabebjerbi031@master:~$ sudo systemctl restart wazuh-manager
```

FIGURE A.57 – Règle de wazuh manager

Integration de pfsensa avec wazuh

Installation de l'agent Wazuh

d'abords on doit mettre à jour le cache des paquets avec la commande "pkg update"

```
round_trip_min/avg/max/stddev = 0.200/0.300/1.110/0.390 ms
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: pkg update
Updating pfSense-core repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense-core repository is up to date.
Updating pfSense repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense repository is up to date.
All repositories are up to date.
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: []
```

FIGURE A.58 – Mis a jour des paquets

Après, on doit mettre à jour le cache des paquets On peut alors installer l'agent

```
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: pkg install wazuh-agent-4.7.3
Updating FreeBSD repository catalogue...
FreeBSD repository is up to date.
Updating pfSense-core repository catalogue...
Fetching meta.conf: 0%
Fetching packagesite.pkg: 0%
pfSense-core repository is up to date.
Updating pfSense repository catalogue...
Fetching meta.conf: 0%[]
```

FIGURE A.59 – Istallation de l'agent Pfsense

Après l'installation de l'agent, on dois modifié le fichier "/var/ossec/etc/ossec.conf" et pointé-le vers votre gestionnaire Wazuh

```
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: /usr/local/etc/rc.d/wazuh-agent enable
wazuh_agent enabled in /etc/rc.conf
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: /usr/local/etc/rc.d/wazuh-agent start
Starting Wazuh Agent: 2024/05/14 19:54:02 wazuh-syscheckd: WARNING: The check_unixaudit option
is deprecated in favor of the SCA module.
success
[2.7.2-RELEASE] [root@pfSense.home.arpa]/root: []
```

FIGURE A.60 – Configuration de ossec.conf

Pour activer l'agent sur pfsense, on a executé cette commande "/usr/local/etc/rc.d/wazuh-agent start"



FIGURE A.61 – Démarrage de l'agent

On a testé cette intégration avec des coordonnées invalides

Username or Password incorrect

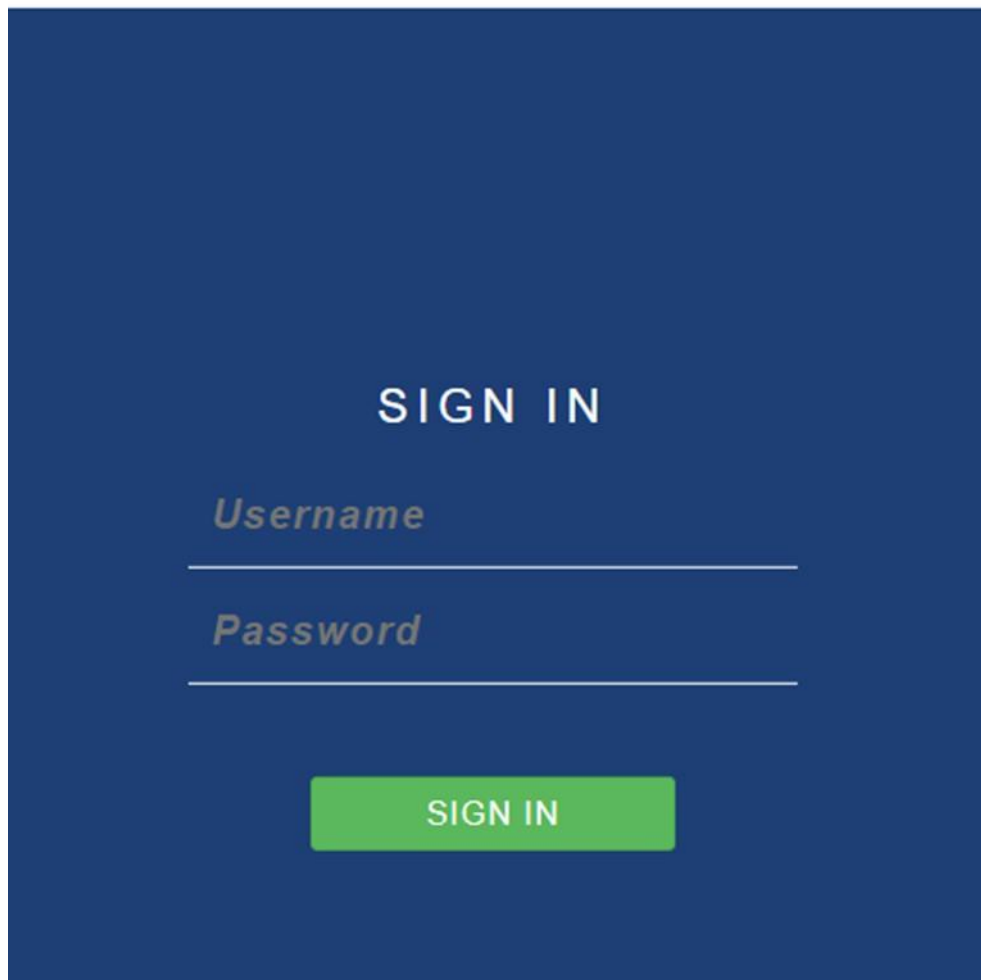


FIGURE A.62 – Test

La figure ci-dessous affiche le resultat de ce test

May 9, 2024 @ 12:18:03.743

002

pfSense.home.arpa

syslog: User authentication failure.

5

2501

Table

JSON

Rule

@timestamp

2024-05-09T19:18:03.743Z

_id

PhnKXo8BnAUwVxiWn_94

agent.id

002

agent.ip

192.168.114.10

agent.name

pfSense.home.arpa

full_log

May 9 19:18:02 pfSense php-fpm[401]: /index.php: webConfigurator authentication error for user 'admin' from: 192.168.114.1

id

1715282283.868199

input.type

log

location

/var/log/auth.log

manager.name

ubuntu

predecoder.hostname

pfSense

predecoder.program_name

php-fpm

predecoder.timestamp

May 9 19:18:02

rule.description

syslog: User authentication failure.

FIGURE A.63 – Résultat de test

Annexe C : Configuration du Serveur Web

Pour tester les attaques sur les deux machines (Ubuntu et Windows), nous avons d'abord configuré un serveur web Apache sur chaque machine.

Machine Ubuntu

Installation et configuration du serveur web Apache

Pour simuler les attaques sur une machine Ubuntu, on a commencé par installer et configurer un serveur web Apache. Cette étape consiste à mettre à jour les paquets locaux et à installer le serveur web Apache

```
rabebjerbi031@agent1:~$ sudo apt update && sudo apt install apache2
Hit:1 http://security.ubuntu.com/ubuntu focal-security InRelease
Hit:2 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu focal InRelease
Get:3 http://europe-central2-a.gce.clouds.archive.ubuntu.com/ubuntu focal-updates InRelease [14 kB]
```

FIGURE A.64 – Installation du serveur web

Une fois l'installation terminée, on doit vérifier que le service Apache fonctionne correctement. Cela garantit que notre serveur web est opérationnel pour les tests ultérieurs.

```
rabebjerbi031@agent1:~$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/lib/systemd/system/apache2.service; enabled; vendor preset: enabled)
   Active: active (running) since Fri 2024-05-03 08:41:57 UTC; 3min 30s ago
     Docs: https://httpd.apache.org/docs/2.4/
```

FIGURE A.65 – Vérification du serveur web

Ensuite, on a configuré l'agent Wazuh pour surveiller les journaux d'accès d'Apache. Cela implique la modification du fichier de configuration de Wazuh pour inclure les journaux spécifiques à Apache.

```
<localfile>
  <log_format>syslog</log_format>
  <location>/var/log/apache2/access.log</location>
</localfile>
```

FIGURE A.66 – Configuration

Pour appliquer les modifications de configuration, on doit redémarré l'agent Wazuh avec la commande "sudo systemctl restart wazuh-agent". Cela permet à Wazuh de commencer à surveiller les journaux d'accès et de générer des alertes en conséquence.

```

rabejjerbi031@agent1:~$ sudo nano /var/ossec/etc/ossec.conf
rabejjerbi031@agent1:~$ sudo systemctl restart wazuh-agent
rabejjerbi031@agent1:~$ █

```

FIGURE A.67 – Redémarrage de l'agent

Machine Windows

Installation et configuration du serveur web Apache

Pour configurer Apache sur Windows, on a navigué vers le répertoire Apache et on a installé le service

```

C:\Windows\system32>cd C:\Apache24\bin
C:\Apache24\bin>.\httpd.exe -k install
Installing the 'Apache2.4' service
The 'Apache2.4' service is successfully installed.
Testing httpd.conf....
Errors reported here must be corrected before the service can be started.
C:\Apache24\bin>.\httpd.exe -k start
C:\Apache24\bin>_

```

FIGURE A.68 – Installation du serveur web

Ensuite, on a confirmé que le serveur web fonctionnait en accédant à l'URL du serveur via un navigateur web

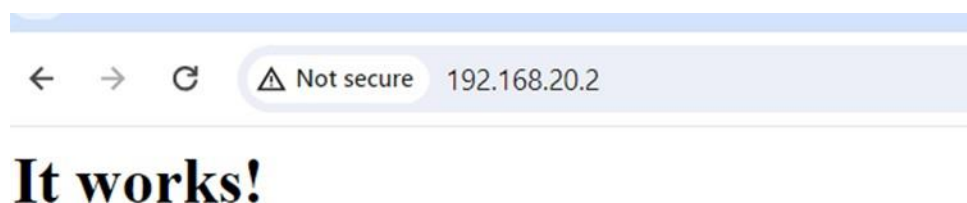


FIGURE A.69 – Vérification du serveur web

Cette page web indique que le serveur Apache sur la machine Windows est opérationnel. Pour surveiller les journaux d'accès Apache avec Wazuh, on a modifié le fichier de configuration ossec.conf pour inclure le chemin du fichier de journalisation d'Apache sur Windows

```
<localfile>  
  <log_format>syslog</log_format>  
  <location>C:\Apache24\logs\access.log</location>  
</localfile>  
|
```

FIGURE A.70 – Configuration

Annexe D : Les règles de Pfsense

Ces règles de pare-feu configurées dans pfSense permettent de sécuriser votre réseau en filtrant le trafic entrant et sortant, en bloquant les sources de trafic non valides et en autorisant seulement les connexions légitimes. Elles jouent un rôle crucial dans la protection de votre réseau contre les menaces externes et internes, tout en assurant que les utilisateurs peuvent accéder aux services nécessaires.

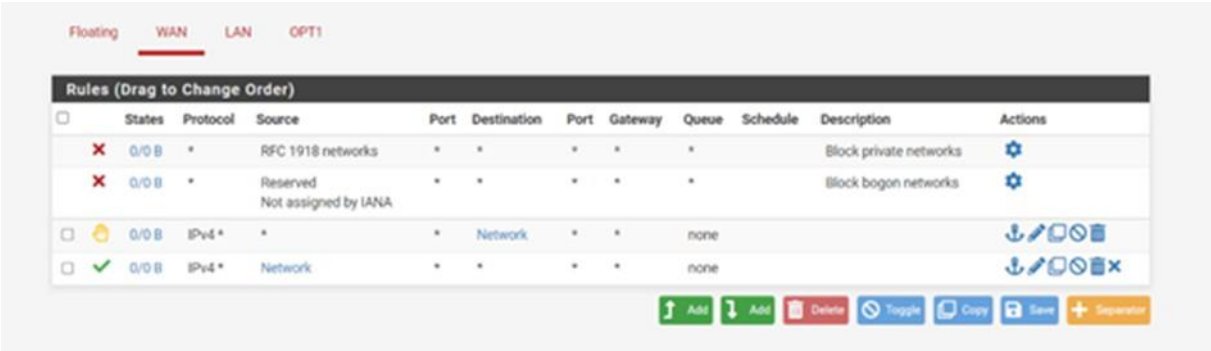


FIGURE A.71 – Règles LAN

La première règle est une règle Anti-Lockout qui permet le trafic HTTP (port 80) et HTTPS (port 443) vers les adresses IP de la LAN. Cette règle est conçue pour éviter que les utilisateurs soient verrouillés hors de l'interface de gestion de pfSense. La deuxième règle autorise tout le trafic IPv4 entrant sur le réseau local (LAN). Cela permet de gérer les communications internes sur le réseau LAN.



FIGURE A.72 – Règles WAN

La première règle bloque le trafic provenant des réseaux privés définis par la RFC 1918. Ces réseaux ne devraient normalement pas être routés sur Internet et sont souvent utilisés pour des adresses IP internes. La deuxième règle bloque les réseaux "bogon", qui sont des plages

d'adresses IP réservées ou non attribuées par l'IANA. Ces réseaux ne devraient pas être visibles sur Internet et leur présence peut indiquer un trafic malveillant. La troisième règle autorise tout le trafic IPv4 entrant depuis n'importe quelle source vers n'importe quelle destination sur le réseau WAN, sans aucune restriction supplémentaire. La quatrième règle autorise également tout le trafic IPv4 entrant sur le réseau WAN. Ces règles aident à sécuriser votre réseau en filtrant les sources de trafic non valides et en permettant seulement les connexions légitimes vers et depuis votre réseau.